

Universidad Nacional Autónoma de México



Facultad de Ingeniería

Alumno:

Lara Hernandez Angel Husiel - 320060829

Lugo Manzano Rodrigo - 320206968

Flores Colin Victor Jaziel - 320266083

Garcia Cortes Adolfo de Jesus - 320317264

Seguridad informatica basica

Semestre: 2027-1

Actividad 8

Análisis y Mapeo de The NIST Cybersecurity Framework (CSF) 2.0 en las Clases, Prácticas, Presentaciones y Tareas del Curso

Fecha de Entrega:

14 de Noviembre del 2026

Índice

1 Introducción y Alcance de la Revisión de The NIST CSF 2.0 en el Curso **1**
1.1 Estructura del Framework en `csf2.xlsx` 1
1.2 Niveles de Aplicación Evaluados 2

2 Revisión de Carpetas e Historial Completo del Curso **2**

3 Resumen Estadístico de Cobertura y Aplicación en el Curso **6**

4 Listado Detallado de Subcategorías y Actividades Vistas y Aplicadas por Función . . . **7**
4.1 Función 1: GOVERN (GV) — Gobernanza de Ciberseguridad 7
4.2 Función 2: IDENTIFY (ID) — Identificación de Activos, Vulnerabilidades y Riesgos 11
4.3 Función 3: PROTECT (PR) — Salvaguardas y Controles de Protección 15
4.4 Función 4: DETECT (DE) — Monitoreo Continuo y Análisis de Eventos Adversos 20
4.5 Función 5: RESPOND (RS) — Respuesta y Mitigación de Incidentes 22
4.6 Función 6: RECOVER (RC) — Recuperación y Restauración 24

5 Matriz Completa de las 106 Subcategorías de `csf2.xlsx` en el Curso **25**

6 Conclusiones sobre la Aplicación del NIST CSF 2.0 en el Curso **29**

1. Introducción y Alcance de la Revisión de The NIST CSF 2.0 en el Curso

El presente documento desarrolla la **Actividad 8** de la asignatura *Seguridad Informática Básica*, cuyo propósito es revisar el marco de referencia **The NIST Cybersecurity Framework (CSF) 2.0** (`NIST CSWP 29` y el archivo de referencia de la actividad `csf2.xlsx`) (National Institute of Standards and Technology, 2024) e identificar qué **Subcategorías** y **Actividades / Ejemplos de Implementación** se han abordado a lo largo de **todo el curso**, abarcando:

- **Prácticas de Laboratorio (Práctica 1 a Práctica 7):** Ejecución técnica directa de herramientas y comandos de administración de sistemas, reconocimiento pasivo/activo (OSINT), escaneo de redes y vulnerabilidades, auditoría de contraseñas, escalación de privilegios, análisis de integridad criptográfica, auditoría de respaldos y pivoteo de red.
- **Actividades de Clase (Actividad 1 a Actividad 7):** Ejercicios metodológicos desarrollados durante las sesiones de clase sobre fundamentos de seguridad de la información vs. ciberseguridad, análisis de contexto organizacional, levantamiento de inventarios de activos y diagramas de red, evaluación de vulnerabilidades con `CVSS v3.1` / `CVE` / `CWE`, inteligencia de amenazas, construcción de registros de riesgos y modelado cuantitativo/cualitativo de riesgos con planes de acción (*POA&M*) e indicadores (*KRIs*).
- **Presentaciones en Clase (`Actividad3/html/index.html`):** Exposición interactiva sobre actores de amenaza, análisis de ciberataques recientes y taxonomía de adversarios.
- **Tareas e Investigación (Tarea 1 a Tarea 4):** Análisis de ponencias y conferencias especializadas del **UNAM-CERT** (*Estrategias de Deception y Honeypots*), investigación sobre **Vulnerabilidades Zero-Day, Mercados de Exploits y Ética Profesional**, y análisis técnico de 6 conferencias del congreso internacional **MITRE ATT&CKcon 7.0**.

1.1. Estructura del Framework en `csf2.xlsx`

De acuerdo con el archivo `csf2.xlsx` proporcionado para la Actividad 8, el núcleo (*Core*) de **The NIST Cybersecurity Framework 2.0** se compone de **6 Funciones**, **22 Categorías** y **106 Subcategorías activas**, cada una acompañada por sus respectivos **Ejemplos de Implementación (`Ex1`, `Ex2`, `...`)** que describen las actividades concretas orientadas a la acción:

1. **GOVERN (`GV`) — Gobernanza (6 categorías, 31 subcategorías):** Contexto organizacional (`GV.OC`), Estrategia de gestión de riesgos (`GV.RM`), Roles, responsabilidades y autoridades (`GV.RR`), Políticas (`GV.PO`), Supervisión (`GV.OV`) y Gestión de riesgos de la cadena de suministro (`GV.SC`).
2. **IDENTIFY (`ID`) — Identificar (3 categorías, 21 subcategorías):** Gestión de activos (`ID.AM`), Evaluación de riesgos (`ID.RA`) y Mejora continua (`ID.IM`).
3. **PROTECT (`PR`) — Proteger (5 categorías, 22 subcategorías):** Gestión de identidades, autenticación y control de acceso (`PR.AA`), Concientización y capacitación (`PR.AT`), Seguridad de los datos (`PR.DS`), Seguridad de plataformas (`PR.PS`) y Resiliencia de la infraestructura tecnológica (`PR.IR`).
4. **DETECT (`DE`) — Detectar (2 categorías, 11 subcategorías):** Monitoreo continuo (`DE.CM`) y Análisis de eventos adversos (`DE.AE`).

5. **RESPOND (RS) — Responder (4 categorías, 13 subcategorías):** Gestión de incidentes (RS.MA), Análisis de incidentes (RS.AN), Comunicación y reporte de respuesta (RS.CO) y Mitigación de incidentes (RS.MI).

6. **RECOVER (RC) — Recuperar (2 categorías, 8 subcategorías):** Ejecución del plan de recuperación (RC.RP) y Comunicación de recuperación (RC.CO).

1.2. Niveles de Aplicación Evaluados

Para responder de manera clara y diferenciada a las preguntas **¿Dónde apareció?** y **¿Se aplicó en algún momento?**, cada subcategoría encontrada en el historial del curso se clasifica según cómo se trabajó:

- **SÍ — Aplicación Práctica / Técnica en Laboratorio (Prácticas 1 a 7):** La actividad del framework se **ejecutó de forma real y práctica en terminal/laboratorio** mediante comandos, scripts, herramientas de auditoría o configuración de sistemas operativos sobre las máquinas virtuales del curso (EvilBox, webserver y codeserver) o dominios autorizados (ingenieria.unam.mx / unam.mx).

- **SÍ — Aplicación Metodológica en Ejercicios de Clase y Presentaciones (Actividades 1 a 7):** La actividad se **aplicó realizando el ejercicio metodológico o documental completo** solicitado en clase (construcción de inventarios de activos, diagramación de redes, calificación de CVEs con CVSS v3.1, diseño de taxonomía de amenazas, llenado de plantillas de registro de riesgos, cálculo cuantitativo de frecuencia/impacto y diseño de planes de acción y KRIs).

- **Visto de Forma Teórica / Analítica (Tareas 1 a 4, Conferencias y Conceptos de Clase):** La actividad se **vio, estudió o analizó conceptualmente** en clase, lecturas, tareas de investigación o conferencias (UNAM-CERT, Zero-Days, MITRE ATT&CKcon 7.0), o bien se dejó planteada como propuesta teórica de mitigación sin llegar a ejecutarse técnicamente en un sistema real.

2. Revisión de Carpetas e Historial Completo del Curso

En la Tabla 1 se presenta el inventario de todas las carpetas revisadas en el repositorio del curso (Practica1 a Practica7, Actividad 1 a Actividad7, Actividad3/html y Tarea1 a Tarea4), detallando las actividades técnicas y académicas realizadas en cada una.

Tabla 1: Historial completo de prácticas, actividades, presentaciones y tareas revisadas en el repositorio.

Carpeta / Entregable	Tipo y Tema del Trabajo	Actividades Vistas y Realizadas en el Curso	Funciones CSF 2.0 Relacionadas
A. PRÁCTICAS DE LABORATORIO (Ejecución Técnica Real)			

Carpeta / Entregable	Tipo y Tema del Trabajo	Actividades Vistas y Realizadas en el Curso	Funciones CSF 2.0 Relacionadas
Práctica 1 (`Practica1/main.tex`)	Configuración de Entorno Linux, Privilegios y Herramientas	Instalación de Debian 13 (`EvilBox`) en VMware Workstation Pro, particionado, creación de usuario estándar sin operar como `root`, asignación de permisos mínimos en `/etc/sudoers` (`usermod -aG sudo`), validación de red (`ping`), mantenimiento del sistema (`apt update && apt upgrade`, `/etc/apt/sources.list`) e instalación de herramientas (`nmap`, `hydra`, `subfinder`, `httpx`, `nuclei`, `amass`, `torbrowser`).	`ID.AM-08`, `PR.AA-01`, `PR.AA-02`, `PR.AA-05`, `PR.PS-01`, `PR.PS-02`, `PR.PS-05`
Práctica 2 (`Practica2/main.tex`)	Reconocimiento Pasivo/Activo (OSINT) y Escaneo Web Externo	Gestión de llaves de API (`GitHub`, `VirusTotal` en `provider-config.yaml`), enumeración de subdominios de `ingenieria.unam.mx` (62) y `unam.mx` (4,984; 143 filtrados) con `subfinder`, mapeo de bloques CIDR `/24` y `/16` con `dig` y `whois` (detectando activo alojado en AWS `35.172.49.191`), inventario de servidores web y tecnologías con `httpx` (versiones EOL de PHP/Apache) y escaneo de vulnerabilidades con `nuclei` sobre `ssa.ingenieria.unam.mx` (Cloudflare WAF, TLS 1.0/1.1 obsoletos, cifrados CBC débiles, falta de SRI).	`GV.OC-05`, `ID.AM-01`, `ID.AM-02`, `ID.AM-04`, `ID.AM-08`, `ID.RA-01`, `ID.RA-02`, `PR.DS-02`, `PR.PS-02`
Práctica 3 (`Practica3/main.tex`)	Escaneo de Red Local con Nmap y Auditoría de Contraseñas con Hydra	Descubrimiento de hosts activos en `192.168.177.0/24` (`nmap -sP`), escaneo de puertos rápido (`-F`) y completo (`-p-`), detección de servicios y versiones (`-sV`, `-A`) sobre `webserver` (`192.168.177.129`: Apache 2.4.10 en puerto 80, OpenSSH 6.7p1 en puerto 13337, rpcbind 111). Auditoría de fuerza bruta por diccionario con `Hydra` (diccionario NCSC 100k) obteniendo la credencial débil `webadmin:toronto` y verificando acceso por SSH (`id`).	`ID.AM-01` a `ID.AM-03`, `ID.RA-01`, `ID.IM-02`, `PR.AA-03`, `PR.PS-01`
Práctica 4 (`Practica4/main.tex`)	Auditoría Local con LinPEAS y Escalación de Privilegios	Transferencia de `linpeas.sh` por `scp` a `webserver`, ejecución y análisis de vulnerabilidades locales: sistema Debian 8.11 Jessie EOL (kernel `3.16.0-6-686-pae`), 13 CVEs de escalación (incluyendo `DirtyCow CVE-2016-5195` y `PwnKit CVE-2021-4034` en binario SUID `/usr/bin/pkexec`) y permisos inseguros (`666`/`777`) en sockets Unix. Compilación y ejecución del exploit `CVE-2021-4034` obteniendo `root` (`uid=0`) y limpieza de artefactos (`make clean`).	`ID.RA-01`, `ID.IM-02`, `PR.AA-05`, `PR.PS-01`, `PR.PS-02`, `RS.AN-08`, `RS.MI-02`

Carpeta / Entregable	Tipo y Tema del Trabajo	Actividades Vistas y Realizadas en el Curso	Funciones CSF 2.0 Relacionadas
Práctica 5 (`Practica5/main.tex`)	Extracción de Hashes, Integridad SHA-256 y Cracking con John the Ripper	Extracción de `/etc/passwd` y `/etc/shadow` como `root`, verificación de integridad criptográfica calculando hashes `sha256sum` antes y después de la transferencia por `scp`, análisis del formato `SHA512-crypt` (`$6$`) y sales, combinación con `unshadow` y cracking offline con `John the Ripper` recuperando `webadmin:toronto` y `root:Maverick`.	`PR.AA-01`, `PR.AA-03`, `PR.DS-01`, `PR.DS-02`, `RS.AN-07`, `RC.RP-03`
Práctica 6 (`Practica6/main.tex`)	Post-Explotación, Auditoría de Procesos, Respaldos y Red Interna	Inspección de kernel (`uname -v`), distribución (`/etc/*release`), procesos activos (`ps aux awf`), rutas y tablas de red (`route -n`, `ifconfig -a` descubriendo interfaz interna `eth1 10.0.0.78/24`). Búsqueda de respaldos (`find`, `tar -ztvf` en `/root/respaldo.tar.gz` y `Project.old.tar.gz`) y credenciales en texto claro con `grep -rnI` (`passwords.txt: developer2024: R0b0tRulz!`). Creación del script `escaner.sh` (`ping` + `nc -zv`) descubriendo el host interno `10.0.0.201` (`codeserver`, puertos 5985 WinRM y 3389 RDP).	`ID.AM-01` a `ID.AM-03`, `ID.AM-07`, `ID.RA-01`, `PR.DS-01`, `PR.DS-11`, `PR.IR-01`, `DE.CM-09`, `RS.AN-08`
Práctica 7 (`Practica7/main.tex`)	Segmentación, Pivoteo por Túnel SSH, RDP y Hash de Código Fuente	Comprobación de aislamiento de red entre `192.168.177.0/24` y `10.0.0.0/24` (100 % pérdida de paquetes desde `EvilBox`), creación de túnel SSH con reenvío local de puertos (`ssh -p 13337 -L 3389:10.0.0.201:3389`), acceso remoto RDP con `Remmina` a Windows Server 2012 R2, levantamiento de información con `systeminfo`, inspección del servidor web IIS (`C:\inetpub\wwwroot`) y verificación de integridad criptográfica de `bot.py` con `certutil -hashfile ... SHA256`.	`ID.AM-01` a `ID.AM-03`, `PR.AA-03`, `PR.DS-01`, `PR.DS-02`, `PR.PS-06`, `PR.IR-01`, `RS.AN-07`, `RC.RP-03`
B. ACTIVIDADES DE CLASE Y PRESENTACIONES (Aplicación Metodológica y Documental)			
Actividad 1 (`Actividad 1/main.tex`)	Seguridad de la Información vs. Ciberseguridad y Enfoque Táctico	Análisis comparativo entre Seguridad de la Información (gobierno, políticas normativas ISO 27001, tríada CIA en todo formato) y Ciberseguridad (defensa técnica operativa en el ciberespacio), así como la distinción entre tácticas defensivas (*Blue Team*) y ofensivas (*Red Team* / Ciberinteligencia).	`GV.OC`, `GV.PO-01`, `ID.RA`, `PR.DS`
Actividad 2 (`Actividad2/main.tex` y `Actividad3/main.tex` Sec. 2–3)	Análisis de Contexto Organizacional, Misión y Cadena de Suministro	Metodología para comprender el contexto de una industria (digitalización, ecosistema de proveedores Tier 1/Tier 2, clientes y reguladores), establecer la misión y objetivos de negocio, e identificar servicios críticos y dependencias externas.	`GV.OC-01` a `GV.OC-05`, `GV.SC-01`, `GV.SC-04`

Carpeta / Entregable	Tipo y Tema del Trabajo	Actividades Vistas y Realizadas en el Curso	Funciones CSF 2.0 Relacionadas
Actividad 3 (`Actividad3/main.tex` Sec. 4–7)	Levantamiento de Inventario de Activos y Diagramación de Arquitectura de Red	Ejercicio metodológico de identificación y priorización de activos tecnológicos (hardware, software empresarial, servicios Cloud/SaaS, bases de datos, herramientas de seguridad, endpoints IT/OT/embebidos, servidores web y APIs) y diseño de un diagrama de conectividad segmentado en zonas de confianza con protocolos autorizados.	`ID.AM-01` a `ID.AM-05`, `ID.AM-07`, `PR.AA-01`, `PR.AA-04`, `PR.IR-01`, `PR.IR-03`
Actividad 4 (`Actividad3/main.tex` Sec. 8)	Evaluación de Vulnerabilidades con CVSS v3.1, CVE y CWE	Aplicación de la escala estándar **CVSS v3.1** (0.0 a 10.0) e investigación en el NVD/MITRE para mapear 27 vulnerabilidades reales (`CVE`), clasificar su debilidad subyacente (`CWE`) y definir controles técnicos de mitigación y parcheo por capa tecnológica.	`GV.RM-06`, `ID.RA-01`, `ID.RA-08`, `ID.IM-04`, `PR.PS-01`, `PR.PS-02`, `PR.PS-06`
Actividad 5 y Presentación HTML (`Actividad3/main.tex` Sec. 9–10 y `Actividad3/html/index.html`)	Inteligencia de Amenazas (CTI), Análisis de Incidentes y Taxonomía de Adversarios	Investigación de grupos de amenaza reales (APT, ransomware, hacktivismo), análisis de causa raíz e impacto de 5 ciberataques reales documentados en la industria, y diseño de una taxonomía propia de actores de amenaza internos y externos expuesta mediante una presentación web interactiva en HTML/CSS/JS.	`GV.OV-02`, `GV.SC-07`, `ID.RA-02`, `ID.RA-03`, `DE.AE-07`, `RS.MA-03`, `RS.AN-03`
Actividad 6 (`Actividad4/320206968_Actividad6 (1).pdf`)	Diseño de Escenarios de Riesgo (Forma 1 y Forma 2) y Registro de Riesgos	Redacción estructurada de 10 escenarios de riesgo en dos formatos estándar (**Forma 1**: orientado al impacto y proceso operativo; **Forma 2**: orientado al adversario y activo comprometido) y construcción de la plantilla del **Registro de Riesgos** (propietario del riesgo, nivel de riesgo, estrategia Mitigar/Transferir/Evitar/Aceptar y estado del plan de acción).	`GV.RM-01` a `GV.RM-06`, `GV.RR-02`, `ID.AM-08`, `ID.RA-04` a `ID.RA-06`
Actividad 7 (`Actividad7/main.tex` y Excel `320060829_Actividad7.xlsx`)	Análisis Cuantitativo/Cualitativo de Riesgos, POA&M y KRIs (ShadowAI)	Aplicación de la plantilla detallada de Análisis de Riesgos para el uso no autorizado de IA generativa (*ShadowAI*): cálculo cuantitativo de Frecuencia anual ($F = 4.0$), Impacto promedio ($I_{\text{prom}} = 2.50$ sobre pérdida financiera, costo de respuesta, reputación y cumplimiento regulatorio) y Nivel de Riesgo ($R = F \times I_{\text{prom}} = 10.00$), definición de un Plan de Acción e Hitos (**POA&M**) de 5 puntos con fechas compromiso y diseño de **3 KRIs** de monitoreo continuo.	`GV.RM-01` a `GV.RM-06`, `GV.PO-01`, `GV.PO-02`, `GV.OV-03`, `ID.AM-08`, `ID.RA-04` a `ID.RA-06`, `PR.AT-01`, `PR.DS-02`, `DE.CM-01`, `DE.CM-09`, `DE.AE-03`
C. TAREAS E INVESTIGACIÓN DE CONFERENCIAS (Análisis Teórico y Operativo SOC)			

Carpeta / Entregable	Tipo y Tema del Trabajo	Actividades Vistas y Realizadas en el Curso	Funciones CSF 2.0 Relacionadas
Tarea 1 (`Tarea1/main.tex`)	Estrategias de Deception y Honeypots en Ciberseguridad Defensiva (UNAM-CERT)	Estudio de la ponencia del Diplomado en Ciberseguridad sobre reducción de falsos positivos y fatiga de alertas en el SOC mediante tecnología de ciberengaño (*Deception*): propiedades de señuelos efectivos, despliegue de *Honey files* (`passwords.docx`), *Honey tokens* (llaves API, credenciales VPN), cuentas falsas en Active Directory contra *Kerberoasting* y envío de alertas vía `syslog`/webhooks.	`PR.PS-04`, `DE.CM-03`, `DE.AE-02`, `DE.AE-06`, `DE.AE-08`, `RS.MA-02`, `RS.MA-03`, `RS.AN-03`
Tarea 2 (`Tarea2/main.tex`)	Vulnerabilidades Zero-Day, Mercados de Exploits y Ética Profesional	Análisis de vulnerabilidades de Día Cero y mercados blanco, gris y negro. Estudio de 3 incidentes históricos: `CVE-2023-41990` (*Operation Triangulation* en iMessage), robo de datos y extorsión en *MOVEit Transfer*, y robo de *EternalBlue* a la NSA por *The Shadow Brokers* que desató el ransomware global *WannaCry*. Análisis de intermediarios (*Zero-Day Brokers / Escrow*) y la ética profesional en la divulgación responsable (*Bug Bounty*).	`GV.RR-01`, `ID.RA-01`, `ID.RA-02`, `ID.RA-08`, `DE.AE-07`, `RS.MA-03`, `RS.AN-03`
Tarea 4 (Reporte Tarea 3) (`Tarea4/main.tex` y `320060829_Tarea3.pdf`)	Análisis Técnico de 6 Conferencias de MITRE ATT&CKcon 7.0	1) *Obfuscated Tale*: telemetría de PowerShell (Eventos 4103/4104) y Sysmon (Eventos 1, 7, 17) hacia el SIEM; 2) *Multi-Tenant Kill Chain Correlation*: correlación de identidades e integraciones SaaS entre organizaciones; 3) *The Defensible Minimum*: priorización de controles y aceptación consciente del riesgo residual en organizaciones con recursos limitados; 4) *ATT&CK v21 & ATLAS*: amenazas a sistemas de IA y uso de MCP (*MalChela*); 5) *Measuring ATT&CK Coverage Beyond T1055*: validación de sensores ante inyección de procesos; 6) *Breaking the Defenders*: evasión de AMSI/ETW/BYOVD y borrado de respaldos por ransomware.	`GV.RM-02`, `GV.RR-03`, `ID.RA-02`, `ID.RA-03`, `ID.IM-01`, `ID.IM-02`, `PR.DS-10`, `PR.DS-11`, `PR.PS-04`, `DE.CM-06`, `DE.CM-09`, `DE.AE-02`, `DE.AE-03`

3. Resumen Estadístico de Cobertura y Aplicación en el Curso

La Tabla 2 resume cuántas de las **106 subcategorías activas** del archivo `csf2.xlsx` se vieron a lo largo del semestre y cómo se distribuyen entre **ejecución práctica en laboratorio** (Prácticas 1–7), **aplicación metodológica en ejercicios de clase** (Actividades 1–7 y Presentación HTML) y **estudio teórico/analítico en tareas y conferencias** (Tareas 1–4).

Tabla 2: Resumen cuantitativo de subcategorías del NIST CSF 2.0 vistas y aplicadas en el curso.

Función del NIST CSF 2.0	Categorías	Subcat. en `csf2.xlsx`	Aplicadas en Laboratorio (Prácticas 1–7)	Aplicadas en Clase / Pres. (Act. 1–7)	Vistas en Tareas / Conferencias (Tareas 1–4)	Total Vistas en el Curso
1. GOVERN (`GV`)	6	31	2	19	6	**25 / 31** (80.6 %)
2. IDENTIFY (`ID`)	3	21	10	14	5	**19 / 21** (90.5 %)
3. PROTECT (`PR`)	5	22	12	14	5	**19 / 22** (86.4 %)
4. DETECT (`DE`)	2	11	3	5	9	**10 / 11** (90.9 %)
5. RESPOND (`RS`)	4	13	2	4	8	**10 / 13** (76.9 %)
6. RECOVER (`RC`)	2	8	1	3	4	**6 / 8** (75.0 %)
TOTAL GLOBAL CSF 2.0	**22**	**106**	**30**	**59**	**37**	**89 / 106 (84.0 %)**

Nota: Diversas subcategorías fueron trabajadas en más de una modalidad (por ejemplo, vistas teóricamente en clase/tareas, modeladas en las Actividades 1–7 y ejecutadas técnicamente con herramientas reales en las Prácticas 1–7). El total global de subcategorías únicas abordadas en el curso es de **89 de 106 (84.0 %)**.

4. Listado Detallado de Subcategorías y Actividades Vistas y Aplicadas por Función

A continuación se presenta el desglose pormenorizado de cada una de las **6 Funciones** de **The NIST Cybersecurity Framework 2.0** tomando como base exacta las subcategorías y los *Implementation Examples* (`Ex1`, `Ex2`, ...) del archivo `csf2.xlsx`. Para cada subcategoría se especifica: 1. **Subcategoría y Actividad / Ejemplo de Implementación (`csf2.xlsx`)**. 2. **¿Dónde apareció en el curso?** (indicando la Práctica, Actividad, Presentación o Tarea correspondiente). 3. **¿Se aplicó en algún momento?** (distinguiendo si se ejecutó prácticamente en laboratorio, si se aplicó como ejercicio metodológico en las actividades de clase o si se estudió de forma teórica/analítica en tareas y conferencias).

4.1. Función 1: GOVERN (GV) — Gobernanza de Ciberseguridad

En el curso, la función **GOVERN (`GV`)** se abordó en la **Práctica 2** (identificación técnica de dependencias externas de red y nube), en las **Tareas 2 y 4** (ética profesional en ciberseguridad, priorización de controles bajo recursos limitados y aceptación de riesgo residual) y a lo largo de las **Actividades 1, 2, 5, 6 y 7** (diferencia entre gobierno normativo y controles técnicos, análisis de contexto organizacional, plantillas de registro de riesgos, cálculo cuantitativo de riesgo, políticas ante nuevas tecnologías como IA y métricas de supervisión *KRIs*).

Tabla 3: Subcategorías y actividades de la función **GOVERN (GV)** vistas y aplicadas en el curso.

Subcat. CSF 2.0	**Descripción y Actividad / Ejemplo de Implementación (`csf2.xlsx`)**	**¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)**	**¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)**
`GV.OC-01`	**La misión organizacional se comprende e informa la gestión de riesgos.** • `Ex1`: Compartir la misión, visión y estrategias de servicio de la organización para proporcionar una base que permita identificar riesgos que puedan impedir esa misión.	**Actividad 2 y Actividad 3** (`Actividad2/main.tex` Sec. 3; `Actividad3/main.tex` Sec. 3 "Objetivo de Negocio de la Organización").	**SÍ (Aplicación Metodológica en Clase):** En la Actividad 2 se realizó el ejercicio de definir la misión, visión y objetivos estratégicos de una organización industrial y utilizarlos como punto de partida para identificar los riesgos que comprometen la operación.
`GV.OC-02`	**Las partes interesadas internas y externas y sus expectativas de ciberseguridad se comprenden y consideran.** • `Ex1`: Identificar partes interesadas internas (directivos, empleados). • `Ex2`: Identificar partes interesadas externas (privacidad de clientes, expectativas de socios, cumplimiento ante reguladores, ética ante la sociedad).	**Actividad 2, 3, 6 y 7, y Tarea 2** (`Actividad3/main.tex` Sec. 2–3; `Actividad7/main.tex` Sec. II–III; `Tarea2/main.tex` ética ante la sociedad y usuarios).	**SÍ (Aplicado en Actividades de Clase y Analizado en Tarea 2):** En las Actividades 2, 6 y 7 se mapearon las expectativas de los grupos de interés internos (ingeniería, planta, TI, dirección) y externos (clientes, socios comerciales, reguladores), mientras que en la **Tarea 2** (`Ex2`) se analizaron las expectativas éticas de la sociedad frente a investigadores y fabricantes ante vulnerabilidades críticas.
`GV.OC-03`	**Los requisitos legales, regulatorios y contractuales de ciberseguridad (incluyendo privacidad) se comprenden y gestionan.** • `Ex1`: Gestionar requisitos legales y regulatorios de protección de datos personales. • `Ex2`: Gestionar requisitos contractuales con proveedores, clientes y socios. • `Ex3`: Alinear la estrategia de ciberseguridad con requisitos legales y regulatorios.	**Actividad 1, Actividad 6 y Actividad 7** (`Actividad 1/main.tex` Sec. 1; `Actividad7/main.tex` Sec. III "Riesgo de Cumplimiento o Regulatorio" y Sec. IV).	**SÍ (Aplicación Metodológica en Clase):** En la Actividad 1 se estudió el marco normativo (ISO/IEC 27001), y en la Actividad 7 se evaluó el impacto legal, regulatorio y contractual dentro de la matriz de riesgo (leyes de protección de datos personales LFPDPPP, estándares sectoriales ISO/SAE 21434, TISAX y acuerdos de confidencialidad NDA).
`GV.OC-04`	**Los objetivos, capacidades y servicios críticos de los que dependen las partes interesadas externas se comprenden y comunican.** • `Ex1`: Establecer criterios de criticidad de capacidades y servicios. • `Ex2`: Determinar activos y operaciones de negocio vitales para lograr los objetivos de la misión y el impacto potencial de su pérdida parcial o total.	**Actividad 2, Actividad 3 y Actividad 6** (`Actividad3/main.tex` Sec. 3–4; `Actividad4/320206968_Actividad6(1).pdf`).	**SÍ (Aplicación Metodológica en Clase):** En la Actividad 3 se establecieron criterios de criticidad para seleccionar 12 activos vitales y documentar el impacto operativo en caso de pérdida o interrupción de cada servicio.
`GV.OC-05`	**Los resultados, capacidades y servicios de los que depende la organización se comprenden y comunican.** • `Ex1`: **Crear un inventario de las dependencias de la organización en recursos externos (p. ej., proveedores de alojamiento en la nube) y sus relaciones con los activos**. • `Ex2`: Identificar y documentar dependencias externas que sean posibles puntos de falla.	**Práctica 2 y Actividades 2, 3, 5 y 6** (`Practica2/main.tex` Sec. 3 "Mapeo de bloques CIDR y ASN con dig y whois"; `Actividad3/main.tex` Sec. 2.2 y 5; `Actividad4/320206968_Actividad6(1).pdf`).	**SÍ (Aplicación Práctica en Práctica 2 y Metodológica en Clase):** • **En Práctica 2 (`Ex1`):** Al analizar los subdominios de `unam.mx` mediante `dig` y `whois`, se identificó y documentó que servicios institucionales dependen de alojamiento externo en la nube de **Amazon Web Services (AWS)** en el bloque `35.168.0.0/13` (IP `35.172.49.191`) y de la red CDN/WAF de **Cloudflare** en `ssa.ingenieria.unam.mx`. • **En Actividades 2, 3 y 6 (`Ex1, Ex2`):** Se inventariaron dependencias en proveedores externos de nube (IaaS/SaaS) y proveedores de cadena de suministro como puntos críticos de falla.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
GV.RM-01	**Los objetivos de gestión de riesgos se establecen y acuerdan con las partes interesadas.** • Ex2: Establecer objetivos medibles para la gestión de riesgos de ciberseguridad (p. ej., gestionar la calidad de la capacitación de usuarios, asegurar protección adecuada para sistemas de control industrial).	**Actividad 6 y Actividad 7** (Actividad7/main.tex Sec. IV "Respuesta al Riesgo y Plan de Acción").	**SÍ (Aplicación Metodológica en Clase):** En la Actividad 7 se definieron metas medibles para el control de riesgos: cumplimiento del 70 % de los hitos técnicos antes de la fecha compromiso y capacitación del 95 % del personal técnico con calificación mínima de 85 %.
GV.RM-02	**Las declaraciones de apetito y tolerancia al riesgo se establecen, comunican y mantienen.** • Ex1--Ex2: Traducir el apetito de riesgo en declaraciones de tolerancia al riesgo específicas, medibles y comprensibles. • Ex3: **Refinar los objetivos y el apetito de riesgo periódicamente según la exposición conocida y el riesgo residual**.	**Tarea 4 y Actividades 6 y 7** (Tarea4/main.tex Conf. 3 "The Defensible Minimum"; Actividad7/main.tex Sec. IV y Sec. V "KRIs").	**SÍ (Estudiado en Tarea 4 y Aplicado en Actividad 7):** • **En Tarea 4 (Ex3):** En la conferencia *The Defensible Minimum* (MITRE ATT&CKcon 7.0) se estudió cómo definir un "mínimo defendible" y reconocer explícitamente el **riesgo residual** que la organización acepta o posterga. • **En Actividad 7 (Ex2):** Se tradujo la tolerancia al riesgo en umbrales cuantitativos medibles dentro de 3 KRIs (p. ej., tolerancia de **0 incidentes por trimestre** en filtración de secretos criptográficos y < 50 intentos semanales de conexión a servicios no autorizados).
GV.RM-03	**Las actividades y resultados de gestión de riesgos de ciberseguridad se incluyen en los procesos de gestión de riesgos empresariales (ERM).** • Ex1: **Agregar y gestionar los riesgos de ciberseguridad junto con otros riesgos empresariales (cumplimiento, financieros, operativos, regulatorios, reputacionales, safety)**.	**Actividad 6 y Actividad 7** (Actividad7/main.tex Sec. II "Categoría del Riesgo" y Sec. III "Análisis de Impacto").	**SÍ (Aplicación Metodológica en Actividad 7):** En la plantilla de Análisis de Riesgos de la Actividad 7 se clasificó el riesgo dentro de las categorías empresariales (*Estratégico, Operativo, Financiero, Cumplimiento, Tecnológico*) y se calculó el impacto integrando 4 rubros de negocio: **pérdida de ganancia**, **costo de respuesta**, **impacto reputacional** y **cumplimiento regulatorio**.
GV.RM-04	**Se establece y comunica la dirección estratégica que describe las opciones apropiadas de respuesta al riesgo.** • Ex1: Especificar criterios para aceptar y evitar riesgos según clasificación de datos. • Ex2: Determinar si se transfiere el riesgo (seguros/contratos). • Ex3: Documentar condiciones de modelos de responsabilidad compartida (nube pública).	**Actividad 6 y Actividad 7** (Actividad4/320206968_Actividad6 (1).pdf Sec. 2; Actividad7/main.tex Sec. IV "Respuesta al Riesgo").	**SÍ (Aplicación Metodológica en Actividades 6 y 7):** En las Actividades 6 y 7 se aplicaron y justificaron las cuatro opciones estratégicas de respuesta al riesgo vistas en clase: **Mitigar**, **Transferir**, **Evitar** y **Aceptar**.
GV.RM-05	**Se establecen líneas de comunicación en toda la organización para los riesgos de ciberseguridad.** • Ex1--Ex2: Determinar cómo informar a la dirección a intervalos acordados y cómo se comunicarán los distintos departamentos (operaciones, TI, legal, RR.HH.).	**Actividad 6 y Actividad 7** (Actividad7/main.tex Sec. I, IV y V).	**SÍ (Aplicación Metodológica en Clase):** En los ejercicios de Registro y Análisis de Riesgos (Actividades 6 y 7) se definieron las líneas de reporte periódico entre las áreas técnicas (SOC/TI, Ingeniería, Operaciones), Legal, Recursos Humanos y el Comité de Riesgos.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
GV.RM-06	**Se establece y comunica un método estandarizado para calcular, documentar, categorizar y priorizar los riesgos de ciberseguridad.** • Ex1: **Establecer criterios para usar un enfoque cuantitativo de análisis de riesgos y especificar fórmulas de probabilidad y exposición**. • Ex2: **Crear y usar plantillas (p. ej., un registro de riesgos) para documentar información de riesgos (descripción, exposición, tratamiento y propietario)**. • Ex3--Ex4: Establecer criterios de priorización y lista consistente de categorías.	**Actividad 4, Actividad 6 y Actividad 7** (Actividad3/main.tex Sec. 8 CVSS v3.1; Actividad4/320206968_Actividad6 (1).pdf; Actividad7/main.tex Sec. I–V y Excel 320060829_Actividad07.xlsx).	**SÍ (Aplicación Metodológica Directa en Clases / Actividades 4, 6 y 7):** Esta subcategoría refleja exactamente el trabajo metodológico central del curso: 1) En **Actividad 4** se utilizó el método estandarizado **CVSS v3.1** (Bajo, Medio, Alto, Crítico) para priorizar vulnerabilidades. 2) En **Actividad 6 (Ex2)** se construyó la plantilla del **Registro de Riesgos** redactando escenarios en **Forma 1** y **Forma 2**. 3) En **Actividad 7 (Ex1, Ex4)** se aplicó la plantilla de Excel con fórmulas cuantitativas de Frecuencia anual ($F = 4.0$), Impacto promedio ($I_{\text{prom}} = \frac{3+2+2+3}{4} = 2.50$) y Nivel de Riesgo ($R = F \times I_{\text{prom}} = 10.00$).
GV.RR-01	**El liderazgo organizacional es responsable del riesgo de ciberseguridad y fomenta una cultura consciente del riesgo, ética y en mejora continua.** • Ex2: **Compartir expectativas sobre una cultura segura y ética, especialmente cuando eventos actuales permiten destacar ejemplos positivos o negativos**.	**Tarea 2, Actividad 6 y Actividad 7** (Tarea2/main.tex Sec. "El Papel de la Ética en los Mercados de Exploits"; Actividad7/main.tex).	**SÍ (Analizado a Profundidad en Tarea 2 y Aplicado en Clase):** En la **Tarea 2** se reflexionó extensamente sobre la ética profesional en ciberseguridad a partir de casos reales (*Operation Triangulation*, *MOVEit*, *EternalBlue/WannaCry*), contrastando la venta de exploits en mercados grises/negros contra la divulgación ética y responsable para proteger a los usuarios.
GV.RR-02	**Los roles, responsabilidades y autoridades relacionados con la gestión de riesgos se establecen, comunican y hacen cumplir.** • Ex1--Ex2: Documentar quién es responsable y rinde cuentas (*Owner*) de las actividades de gestión de riesgos.	**Actividad 6 y Actividad 7** (Actividad4/320206968_Actividad6 (1).pdf Columna "Propietario del Riesgo"; Actividad7/main.tex Sec. I y IV).	**SÍ (Aplicación Metodológica en Actividades 6 y 7):** En la plantilla del Registro de Riesgos (Actividad 6) y en el Plan de Acción (Actividad 7) se asignaron formalmente propietarios de riesgo (*Risk Owners*) y responsables de ejecución para cada escenario y control propuesto.
GV.RR-03	**Se asignan recursos adecuados acordes con la estrategia de riesgo, roles y políticas.** • Ex2--Ex3: Identificar asignación de recursos e inversión alineada con la tolerancia y respuesta al riesgo; proveer recursos humanos, de procesos y técnicos.	**Tarea 4 y Actividad 7** (Tarea4/main.tex Conf. 3 "The Defensible Minimum"; Actividad7/main.tex Sec. III–IV).	**SÍ (Analizado en Tarea 4 y Aplicado en Actividad 7):** En la **Tarea 4** se estudió cómo asignar recursos limitados priorizando controles base en PyMEs y organizaciones reales; en la **Actividad 7** se justificó económicamente la inversión en herramientas técnicas frente a pérdidas financieras estimadas.
GV.RR-04	**La ciberseguridad se incluye en las prácticas de recursos humanos.** • Ex4: Definir y hacer cumplir las obligaciones del personal de conocer, adherirse y respetar las políticas de seguridad según su rol.	**Actividad 5, 6 y 7** (Actividad3/main.tex Sec. 10.2 Amenaza Interna; Actividad7/main.tex Sec. IV Acción 5).	**Visto y Planificado en Clase (Actividad 7):** Se incluyó en el Plan de Acción de la Actividad 7 el requisito de firma de políticas de uso aceptable y evaluación obligatoria anual para el personal con acceso a código fuente y datos sensibles.
GV.PO-01 GV.PO-02	**Establecimiento de políticas de gestión de riesgos (GV.PO-01) y su revisión/actualización ante cambios en amenazas y tecnología (GV.PO-02).** • GV.PO-01 Ex1, Ex4: Crear y difundir una política de gestión de riesgos comprensible. • GV.PO-02 Ex4: **Actualizar la política para reflejar cambios en la tecnología (p. ej., adopción de inteligencia artificial)**.	**Actividad 1, Actividad 6 y Actividad 7** (Actividad 1/main.tex Sec. 1; Actividad4/320206968_Actividad6 (1).pdf; Actividad7/main.tex Sec. I–V).	**SÍ (Visto en Actividad 1 y Aplicado en Actividad 7):** En la **Actividad 1** se estudió el rol de las políticas de seguridad de la información. En las **Actividades 6 y 7** se trabajó directamente el ejemplo GV.PO-02 Ex4 (*"adoption of artificial intelligence"*), diseñando los lineamientos de política y controles ante el uso de plataformas de IA generativa (Groq, Claude, DeepSeek) en el trabajo diario.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
GV.OV-01 GV.OV-02 GV.OV-03	**Supervisión (*Oversight*): revisión de resultados de la estrategia (GV.OV-01), ajuste ante incidentes (GV.OV-02) y evaluación del desempeño mediante KPIs y KRIs (GV.OV-03).** • GV.OV-02 Ex3: Revisar la estrategia a la luz de incidentes de ciberseguridad. • GV.OV-03 Ex2: **Revisar indicadores clave de riesgo (KRIs) para identificar riesgos, probabilidad e impacto**.	**Actividad 5, Actividad 6 y Actividad 7** (Actividad3/main.tex Sec. 9.2; Actividad7/main.tex Sec. V "Monitoreo: Indicadores Clave de Riesgo (KRIs)").	**SÍ (Aplicación Metodológica Directa en Actividad 7):** En la Sección V de la **Actividad 7** se aplicó directamente GV.OV-03 Ex2 al diseñar y parametrizar **3 KRIs cuantitativos** con métrica, fuente de telemetría, frecuencia de medición y umbrales de tolerancia para monitorear si el plan de mitigación reduce efectivamente el riesgo.
GV.SC-01 a GV.SC-05 y GV.SC-07	**Gestión de Riesgos de la Cadena de Suministro de Ciberseguridad (C-SCRM): estrategia (GV.SC-01), roles (GV.SC-02), integración en ERM (GV.SC-03), priorización de proveedores por criticidad (GV.SC-04), requisitos contractuales (GV.SC-05) y monitoreo de riesgos de terceros (GV.SC-07).**	**Actividad 2, 3, 5, 6 y 7, Práctica 2 y Tarea 4** (Actividad3/main.tex Sec. 2.2, Sec. 9.2 y Sec. 10.2; Actividad4/320206968_Actividad6 (1).pdf RSK-09; Practica2/main.tex; Tarea4/main.tex Conf. 2 y 6).	**SÍ (Visto y Aplicado Metodológicamente en Clase y Tarea 4):** En las Actividades 2, 5 y 6 se estudió el impacto de ataques a proveedores en la cadena de suministro (como el caso real de Yanfeng y compromisos por enlaces B2B de terceros), en la Tarea 4 se analizó el riesgo de proveedores de servicios administrados (MSP/SaaS), y en la Actividad 6 se documentó su tratamiento mediante mitigación técnica y transferencia contractual.

Subcategorías de GOVERN (GV) no vistas en el curso (6 de 31): GV.RM-07 (cálculo de riesgos positivos / oportunidades SWOT), GV.SC-06 (auditorías de debida diligencia previas a una contratación), GV.SC-08 (simulacros de incidentes conjuntos con proveedores), GV.SC-09 (validación criptográfica de procedencia física de hardware adquirido) y GV.SC-10 (procedimientos de terminación de contratos y devolución de activos de proveedores).

4.2. Función 2: IDENTIFY (ID) — Identificación de Activos, Vulnerabilidades y Riesgos

La función **IDENTIFY (ID)** fue la más ejercitada de forma práctica en todo el semestre (**90.5 % de cobertura**), ya que combina las **Prácticas de Laboratorio 2, 3, 4, 6 y 7** (donde se ejecutaron herramientas reales para descubrir activos de hardware/software, mapear redes, identificar vulnerabilidades y hacer pruebas de penetración) con las **Actividades 3, 4, 5, 6 y 7**, la **Presentación HTML** y las **Tareas 2 y 4**.

Tabla 4: Subcategorías y actividades de la función **IDENTIFY (ID)** vistas y aplicadas en el curso.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
ID.AM-01	**Se mantienen inventarios de hardware gestionados por la organización.** • Ex1: Mantener inventarios de todo tipo de hardware (IT, IoT, OT y dispositivos móviles). • Ex2: **Monitorear/escanear las redes para detectar hardware activo e inventariar hosts**.	**Prácticas 2, 3, 6 y 7, y Actividad 3** (Practica2/main.tex Sec. 3; Practica3/main.tex Sec. "Descubrimiento de hosts con Nmap"; Practica6/main.tex script escaner.sh; Practica7/main.tex; Actividad3/main.tex Sec. 4 y 6).	**SÍ (Aplicación Práctica en Laboratorio y Metodológica en Clase):** • **En Práctica 3 (Ex2):** Se ejecutó nmap -sP 192.168.177.0/24 en el laboratorio para descubrir los equipos activos conectados al segmento de red local (identificando el host 192.168.177.129). • **En Práctica 6 y 7 (Ex2):** Se programó y ejecutó el script escaner.sh (basado en ping sobre 10.0.0.1..254) para descubrir el servidor oculto 10.0.0.201 (codeserver). • **En Actividad 3 (Ex1):** Se elaboró en clase un inventario estructurado de hardware clasificado en endpoints IT, OT e In-Vehicle.
ID.AM-02	**Se mantienen inventarios de software, servicios y sistemas gestionados por la organización.** • Ex1: **Mantener inventarios de todo tipo de software y servicios (aplicaciones comerciales, open-source, servicios web/API y nube)**. • Ex2--Ex3: Monitorear plataformas y mantener un inventario de los sistemas y sus versiones.	**Prácticas 1, 2, 3, 4, 6 y 7, y Actividad 3** (Practica2/main.tex Sec. 2 y 4 subfinder y httpx; Practica3/main.tex nmap -sV -A; Practica6/main.tex uname -v, ps aux awf; Practica7/main.tex systeminfo; Actividad3/main.tex Sec. 5 y 6.2).	**SÍ (Aplicación Práctica Directa en Prácticas 2, 3, 6 y 7, y en Clase):** • **En Práctica 2:** Se ejecutó subfinder y httpx -title -status-code -tech-detect -server sobre los dominios de la UNAM para construir el inventario real de servidores web activos y su stack de software (Apache, Nginx, PHP, IIS, Cloudflare). • **En Práctica 3:** Se ejecutó nmap -p- -sV -A 192.168.177.129 inventariando todos los servicios y versiones del servidor (Apache 2.4.10 en puerto 80, OpenSSH 6.7p1 en 13337, rpcbind en 111). • **En Prácticas 6 y 7:** Se inventarió el sistema operativo y servicios de webserver (Debian 8.11, kernel 3.16.0-6-686-pae) y de codeserver (Windows Server 2012 R2 Standard mediante systeminfo, puertos 5985 WinRM, 3389 RDP, servidor IIS y aplicación bot.py).
ID.AM-03	**Se mantienen representaciones de la comunicación de red autorizada y de los flujos de datos de red internos y externos.** • Ex1--Ex3: Mantener líneas base de flujos de comunicación dentro de las redes de la organización, con terceros y en la nube. • Ex4: **Mantener documentación de puertos, protocolos y servicios de red esperados entre sistemas**.	**Prácticas 2, 3, 6 y 7, y Actividad 3** (Practica2/main.tex mapeo CIDR; Practica6/main.tex route -n, ifconfig -a, /etc/hosts; Practica7/main.tex; Actividad3/main.tex Sec. 5 Cat. 1 y Sec. 7 "Diagrama de Conectividad").	**SÍ (Aplicación Práctica en Laboratorio y Diagramación en Clase):** • **En Prácticas 6 y 7:** Se mapearon las interfaces de red (eth0 hacia 192.168.177.0/24 y eth1 hacia 10.0.0.0/24), tablas de enrutamiento (route -n) y flujos de comunicación permitidos entre las 3 máquinas virtuales (EvilBox ↔ webserver ↔ codeserver). • **En Actividad 3 (Sec. 7):** Se construyó en TikZ un diagrama completo de arquitectura de red dividido en 4 zonas lógicas documentando los protocolos de red entre cada activo (HTTPS, MQTT/TLS, OPC-UA, Modbus TCP, CAN-FD).
ID.AM-04	**Se mantienen inventarios de servicios proporcionados por proveedores.** • Ex1: Inventariar todos los servicios externos utilizados (IaaS, PaaS, SaaS, APIs y servicios alojados externamente).	**Práctica 2 y Actividades 3, 6 y 7** (Practica2/main.tex Sec. 3 y 5; Actividad3/main.tex Sec. 5; Actividad7/main.tex).	**SÍ (Aplicado en Práctica 2 y en Actividades 3 y 7):** En la **Práctica 2** se identificaron servicios externos contratados/utilizados en dominios institucionales (AWS EC2/Cloud, Cloudflare WAF/CDN y librerías JS alojadas en CDNs externos). En las **Actividades 3 y 7** se inventariaron plataformas SaaS/IaaS y APIs de terceros.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
ID.AM-05	**Los activos se priorizan según su clasificación, criticidad, recursos e impacto en la misión.** • Ex1--Ex3: Definir y aplicar criterios para priorizar cada clase de activos según su impacto.	**Actividad 3, Actividad 4 y Actividad 6** (Actividad3/main.tex Sec. 4; Actividad4/320206968_Actividad6 (1).pdf).	**SÍ (Aplicación Metodológica en Clase):** En la Actividad 3 se clasificaron y priorizaron los activos tecnológicos justificando por qué son críticos para la operación, y en la Actividad 6 se priorizaron los escenarios de riesgo asociados a dichos activos.
ID.AM-07	**Se mantienen inventarios de datos y metadatos correspondientes para los tipos de datos designados.** • Ex1: Mantener una lista de tipos de datos sensibles (PII, propiedad intelectual, credenciales, datos operativos). • Ex2: **Descubrir y analizar datos ad hoc para identificar instancias de datos sensibles**.	**Prácticas 5, 6 y 7, y Actividades 3 y 7** (Practica5/main.tex /etc/passwd y /etc/shadow; Practica6/main.tex búsqueda con find y grep -rnI; Practica7/main.tex localización de bot.py; Actividad3/main.tex; Actividad7/main.tex).	**SÍ (Aplicación Práctica en Prácticas 5, 6 y 7, y en Clase):** • **En Práctica 6 (Ex2):** Se realizó el descubrimiento práctico de datos sensibles en el sistema de archivos mediante comandos find y grep -rnI, localizando respaldos ocultos y archivos con contraseñas en texto plano (ProjectX_CodeBackup/config/passwords.txt). • **En Práctica 7:** Se localizó e inventarió el código fuente de la aplicación web y del chatbot (C:\inetpub\wwwroot\index.html y bot.py). • **En Actividades 3 y 7 (Ex1, Ex3):** Se inventariaron y clasificaron los tipos de datos críticos (propiedad intelectual, código fuente, llaves criptográficas y datos personales PII).
ID.AM-08	**Los sistemas, hardware, software, servicios y datos se gestionan a lo largo de su ciclo de vida.** • Ex3: **Identificar usos no oficiales de tecnología para cumplir objetivos de la misión (es decir, Shadow IT / Shadow AI)**. • Ex4: **Identificar periódicamente sistemas, software y servicios obsoletos/redundantes que incrementan innecesariamente la superficie de ataque**. • Ex5: Configurar y asegurar adecuadamente los sistemas antes de su despliegue.	**Prácticas 1, 2 y 4, y Actividades 6 y 7** (Practica1/main.tex; Practica2/main.tex Sec. 4; Practica4/main.tex Sec. "Enumeración con LinPEAS"; Actividad4/320206968_Actividad6 (1).pdf RK-007; Actividad7/main.tex).	**SÍ (Aplicación Práctica en Prácticas 1, 2 y 4, y Metodológica en Act. 6 y 7):** • **En Práctica 2 y Práctica 4 (Ex4):** Se identificaron sistemas al final de su ciclo de vida (EOL) que incrementaban críticamente la superficie de ataque: servidores universitarios ejecutando PHP 5.3.3/5.4.16 y Apache 2.2.15 (Práctica 2), y el servidor webserver corriendo Debian 8.11 Jessie con kernel 3.16 sin soporte (Práctica 4). • **En Actividades 6 y 7 (Ex3):** Se desarrolló de forma íntegra el análisis del uso no autorizado de tecnología (**ShadowAI**: uso de Groq, Claude, DeepSeek y navegadores con IA sin autorización).
ID.RA-01	**Las vulnerabilidades en los activos se identifican, validan y registran.** • Ex1: **Usar tecnologías de gestión/escaneo de vulnerabilidades para identificar software sin parches y mal configurado**. • Ex2: Evaluar arquitecturas de red y sistemas en busca de debilidades. • Ex3: Revisar, analizar o probar software para identificar vulnerabilidades de configuración por defecto. • Ex5: Monitorear fuentes de ciberinteligencia sobre nuevas vulnerabilidades (NVD/CVE).	**Prácticas 2, 3, 4, 5 y 6, Actividad 4 y Tarea 2** (Practica2/main.tex Sec. 5 nuclei; Practica3/main.tex nmap + Hydra; Practica4/main.tex LinPEAS + CVE-2021-4034; Actividad3/main.tex Sec. 8; Tarea2/main.tex).	**SÍ (Aplicación Práctica Directa en Laboratorio y Metodológica en Clase):** • **En Práctica 2 (Ex1, Ex3):** Se ejecutó el escáner automatizado nuclei sobre ssa.ingenieria.unam.mx, identificando y validando protocolos obsoletos (TLS 1.0 y TLS 1.1), suites de cifrado débiles en modo CBC y falta de *Subresource Integrity* (SRI). • **En Práctica 4 (Ex1, Ex2):** Se ejecutó linpeas.sh sobre webserver, detectando y validando **13 vulnerabilidades CVE de escalación de privilegios** (CVE-2021-4034 *PwnKit*, CVE-2016-5195 *DirtyCow*, CVE-2017-0358) y permisos inseguros en sockets. • **En Actividad 4 (Ex5):** Se investigaron y documentaron **27 CVEs reales** con su código CWE y puntaje **CVSS v3.1**.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
ID.RA-02	**Se recibe inteligencia de amenazas cibernéticas (CTI) de foros y fuentes de intercambio de información.** • Ex1: **Configurar herramientas y tecnologías de ciberseguridad para ingerir feeds/fuentes de inteligencia de amenazas**. • Ex2: Recibir y revisar avisos sobre actores de amenaza actuales y sus **TTPs**. • Ex3: Monitorear fuentes de CTI sobre tipos de vulnerabilidades en tecnologías emergentes (IA).	**Práctica 2, Actividad 5, Presentación HTML, Actividad 7 y Tareas 2 y 4** (Practica2/main.tex Sec. 1 configuración de API VirusTotal/GitHub; Actividad3/main.tex Sec. 9–10; Actividad3/html/index.html; Tarea4/main.tex Conf. 4 MITRE ATT&CK v21 y ATLAS).	**SÍ (Aplicado en Práctica 2, Actividades 5 y 7, y Analizado en Tarea 4):** • **En Práctica 2 (Ex1):** Se configuró la herramienta subfinder (provider-config.yaml) para consumir directamente las APIs de inteligencia de **VirusTotal** y **GitHub**. • **En Actividad 5 y Presentación HTML (Ex2):** Se recopilaron reportes de ciberinteligencia para documentar las TTPs de grupos APT y ransomware. • **En Tarea 4 y Actividad 7 (Ex3):** Se analizaron las actualizaciones de **MITRE ATT&CK v21**, **MITRE ATLAS** y **OWASP Top 10 for LLM** sobre amenazas y vulnerabilidades en sistemas de Inteligencia Artificial.
ID.RA-03	**Las amenazas internas y externas a la organización se identifican y registran.** • Ex1: Usar ciberinteligencia para mantener conocimiento de los actores de amenaza y sus TTPs. • Ex3: Implementar procesos para identificar actores de amenaza internos (*insider threats*).	**Actividad 5, Presentación HTML (Actividad3/html/index.html), Actividad 6, Actividad 7 y Tarea 4** (Actividad3/main.tex Sec. 9–10; Actividad7/main.tex Sec. II).	**SÍ (Aplicado en Clase y Expuesto en Presentación Interactiva HTML):** En la Actividad 5 y en la presentación web Actividad3/html/index.html se construyó y presentó en clase una taxonomía completa de actores de amenaza que clasifica tanto adversarios externos (Estado-Nación, Cibercrimen/Ransomware, Hacktivismo, Mercenarios/Brokers de acceso inicial) como **actores internos** (*Insiders*).
ID.RA-04 ID.RA-05	**Identificación y registro de impactos potenciales y probabilidades de que las amenazas exploten vulnerabilidades (ID.RA-04) y uso de amenazas, vulnerabilidades, probabilidades e impactos para comprender el riesgo inherente y priorizar respuestas (ID.RA-05).** • ID.RA-04 Ex1: Estimar la probabilidad e impacto de escenarios de riesgo y registrarlos en registros de riesgos. • ID.RA-05 Ex1--Ex2: Desarrollar modelos de amenazas y priorizar asignaciones de recursos según probabilidades e impactos estimados.	**Actividad 6 y Actividad 7** (Actividad4/ 320206968_Actividad6 (1).pdf Sec. 1–3; Actividad7/main.tex Sec. I–IV y Excel 320060829_Actividad07.xlsx).	**SÍ (Aplicación Metodológica Completa en Actividades 6 y 7):** En la **Actividad 6** se redactaron y evaluaron 10 escenarios de riesgo cruzando amenaza, vulnerabilidad, activo e impacto. En la **Actividad 7** se realizó la estimación cuantitativa de frecuencia ($F = 4.0$ eventos/año) e impacto multivariable ($I_{\text{prom}} = 2.50$) para obtener el nivel de riesgo inherente ($R = 10.00$ ALTO).
ID.RA-06	**Las respuestas al riesgo se eligen, priorizan, planifican, rastrean y comunican.** • Ex1: Aplicar criterios para decidir si aceptar, transferir, mitigar o evitar el riesgo. • Ex2: Seleccionar controles compensatorios para mitigar el riesgo. • Ex3: **Rastrear el progreso de la implementación de la respuesta al riesgo (p. ej., plan de acción e hitos [POA&M], registro de riesgos, reporte detallado de riesgo)**.	**Actividad 6 y Actividad 7** (Actividad4/ 320206968_Actividad6 (1).pdf Sec. 2; Actividad7/main.tex Sec. IV "Respuesta al Riesgo y Plan de Acción").	**SÍ (Aplicación Metodológica Exacta en Actividades 6 y 7):** En el curso se elaboraron exactamente los tres artefactos citados en ID.RA-06 Ex3 de csf2.xlsx: 1) El **Registro de Riesgos (*Risk Register*)** en la Actividad 6. 2) El **Reporte Detallado de Riesgo (*Risk Detail Report*)** en la Actividad 7. 3) El **Plan de Acción e Hitos (*POA&M*)** con 5 acciones concretas, área responsable y fechas compromiso de implementación.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
ID.RA-07	**Los cambios y excepciones se gestionan, evalúan por su impacto en el riesgo, registran y rastrean.** • Ex4: Revisar periódicamente los riesgos que fueron aceptados con base en acciones o hitos futuros planificados.	**Tarea 4 y Actividad 7** (Tarea4/main.tex Conf. 3 "The Defensible Minimum"; Actividad7/main.tex Sec. IV).	**Visto en Tarea 4 y Planificado en Actividad 7:** En la Tarea 4 (Conferencia 3) se estudió la gestión y revisión periódica del riesgo residual aceptado, y en la Actividad 7 se definieron las condiciones de excepción para el uso de herramientas de IA aprobadas.
ID.RA-08	**Se establecen procesos para recibir, analizar y responder a divulgaciones de vulnerabilidades.** • Ex1--Ex2: Procesar, analizar el impacto y responder a divulgaciones de vulnerabilidades (*vulnerability disclosures*).	**Tarea 2 y Actividad 4** (Tarea2/main.tex Sec. "Mercados de Exploits" y "Divulgación Responsable / Bug Bounty"; Actividad3/main.tex Sec. 8).	**Estudiado a Fondo en Tarea 2 y Aplicado en Actividad 4:** En la **Tarea 2** se estudió el ciclo completo de divulgación de vulnerabilidades (*Zero-Days*, mercados blanco/gris/negro, plataformas de *Bug Bounty* y parcheo por fabricantes). En la **Actividad 4** se analizaron avisos públicos de vulnerabilidades (CVE) para establecer medidas de remediación.
ID.IM-01 ID.IM-02	**Se identifican mejoras a partir de evaluaciones (ID.IM-01) y a partir de pruebas y ejercicios de seguridad (ID.IM-02).** • ID.IM-01 Ex1: Realizar autoevaluaciones considerando amenazas y TTPs actuales. • ID.IM-02 Ex4: **Realizar pruebas de penetración (*penetration testing*) para identificar oportunidades de mejorar la postura de seguridad de sistemas seleccionados**.	**Prácticas 2, 3, 4, 5, 6 y 7, Actividad 8 y Tarea 4** (Practica2/main.tex a Practica7/main.tex; Tarea4/main.tex Conf. 5 "Measuring ATT&CK Coverage Through Real Malware Tradecraft").	**SÍ (Aplicación Práctica Completa en Prácticas 2 a 7 y Analizado en Tarea 4):** • **En Laboratorio (Prácticas 2 a 7):** Se ejecutó una cadena completa de **Penetration Testing** (ID.IM-02 Ex4): reconocimiento externo (subfinder, httpx, nuclei), escaneo de puertos (nmap), ataque de diccionario (Hydra), enumeración y explotación local (LinPEAS + CVE-2021-4034), cracking de hashes (John the Ripper), auditoría post-explotación de respaldos y movimiento lateral por túnel SSH (ssh -L) hacia codeserver, documentando en cada práctica las mejoras necesarias. • **En Tarea 4 (Conf. 5):** Se analizó cómo evaluar y mejorar la cobertura real de detección mediante pruebas basadas en técnicas reales de malware (T1055).
ID.IM-03 ID.IM-04	**Identificación de mejoras en procesos operativos (ID.IM-03) y establecimiento/comunicación de planes de ciberseguridad y gestión de vulnerabilidades (ID.IM-04).** • ID.IM-04 Ex3: **Crear un plan de gestión de vulnerabilidades para identificar y evaluar todo tipo de vulnerabilidades y priorizar respuestas**.	**Actividad 4, Actividad 6 y Actividad 7** (Actividad3/main.tex Sec. 8; Actividad4/ 320206968_Actividad6 (1).pdf; Actividad7/main.tex Sec. IV–V).	**SÍ (Aplicación Metodológica en Actividades 4, 6 y 7):** En la Actividad 4 se estructuró el plan de mitigación priorizado por severidad CVSS v3.1 para 27 vulnerabilidades, y en las Actividades 6 y 7 se formalizaron los planes de tratamiento y seguimiento continuo.

Subcategorías de IDENTIFY (ID) no vistas en el curso (2 de 21): ID.RA-09 (evaluación previa a la compra de la autenticidad física de hardware/software) e ID.RA-10 (auditoría formal a proveedores previa a su contratación).

4.3. Función 3: PROTECT (PR) — Salvaguardas y Controles de Protección

La función **PROTECT (PR)** se aplicó de forma muy intensa en las **Prácticas 1, 2, 3, 4, 5, 6 y 7** —tanto configurando mecanismos de protección reales en Linux/Windows como comprobando experimentalmente qué sucede cuando dichos controles fallan— y se complementó en las **Actividades 1, 3, 4, 6 y 7** y en la **Tarea 4**.

Tabla 5: Subcategorías y actividades de la función **PROTECT (PR)** vistas y aplicadas en el curso.

Subcat. CSF 2.0	**Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)**	**¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)**	**¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)**
PR.AA-01 PR.AA-02	**Gestión de identidades y credenciales para usuarios, servicios y hardware (PR.AA-01) y vinculación de identidades a credenciales individuales (PR.AA-02).** • PR.AA-01 Ex1--Ex2: Gestionar cuentas de usuarios y emitir/gestionar certificados, tokens de API y llaves criptográficas. • PR.AA-02 Ex2: Emitir una credencial distinta para cada persona (evitar credenciales compartidas).	**Prácticas 1, 2, 5 y 6, y Actividades 3 y 7** (Practica1/main.tex creación de cuentas en Debian 13; Practica2/main.tex gestión de API keys en provider-config.yaml; Practica5/main.tex /etc/passwd y /etc/shadow; Practica6/main.tex; Actividad3/main.tex; Actividad7/main.tex).	**SÍ (Aplicación Práctica en Prácticas 1, 2, 5 y 6, y Metodológica en Clase):** • **En Práctica 1:** Se creó y configuró una cuenta de usuario individual en Debian 13 separada de la cuenta administrativa root. • **En Práctica 2:** Se generaron y configuraron tokens de autenticación de API (GitHub y VirusTotal) en archivos de configuración protegidos. • **En Prácticas 5 y 6:** Se inspeccionaron los archivos de gestión de cuentas y hashes en Linux (/etc/passwd, /etc/shadow) y se demostró el peligro de credenciales compartidas en archivos de configuración (passwords.txt).
PR.AA-03	**Los usuarios, servicios y hardware son autenticados.** • Ex1: Requerir autenticación multifactor (MFA). • Ex2: **Hacer cumplir políticas de fortaleza mínima de contraseñas, PINs y autenticadores similares**.	**Prácticas 3, 5, 6 y 7, y Actividades 3, 6 y 7** (Practica3/main.tex auditoría SSH con Hydra; Practica5/main.tex auditoría de hashes con John the Ripper; Practica6/main.tex; Practica7/main.tex autenticación SSH y RDP).	**SÍ (Auditado Prácticamente en Prácticas 3, 5, 6 y 7, y Diseñado en Clase):** • **En Práctica 3 (Ex2):** Se auditó experimentalmente la fortaleza de contraseñas del servicio SSH ejecutando Hydra con el diccionario de las 100,000 contraseñas más comunes del NCSC, logrando descubrir que la cuenta webadmin usaba la contraseña débil toronto. • **En Práctica 5 (Ex2):** Mediante unshadow y John the Ripper se auditaron los hashes SHA512-crypt de /etc/shadow, demostrando que incluso con un algoritmo de hash fuerte (6), una contraseña de diccionario sin complejidad (root:Maverick) es vulnerable a ataques offline. • **En Práctica 7:** Se realizó autenticación remota por SSH y escritorio remoto RDP (Remmina) con las credenciales recuperadas (developer2024:R0b0tRulz!).
PR.AA-04	**Las aserciones de identidad se protegen, transmiten y verifican.** • Ex1--Ex3: Proteger aserciones de identidad en sistemas Single Sign-On (SSO) y federados (OAuth 2.0, OIDC, SAML).	**Actividad 3, Actividad 6, Actividad 7 y Tarea 4** (Actividad3/main.tex Sec. 4 y 6.2; Actividad7/main.tex Sec. IV Acción 4; Tarea4/main.tex Conf. 2 sesiones SSO/SaaS).	**SÍ (Aplicado en Actividades 3 y 7, y Analizado en Tarea 4):** En las Actividades 3 y 7 se especificó el uso de federación SSO y tokens OAuth 2.0 / OIDC, y en la Tarea 4 (Conferencia 2) se analizó cómo proteger y correlacionar aserciones de identidad en entornos SaaS multi-inquilino.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
PR.AA-05	**Los permisos de acceso, derechos y autorizaciones se definen, gestionan y aplican incorporando los principios de mínimo privilegio y separación de funciones.** • Ex1: Revisar privilegios de acceso lógico periódicamente. • Ex3: **Restringir el acceso y los privilegios al mínimo necesario (principio de mínimo privilegio)**.	**Práctica 1 y Práctica 4, y Actividades 3, 4, 6 y 7** (Practica1/main.tex Sec. "Configuración de Sudoers"; Practica4/main.tex Sec. "Enumeración con LinPEAS y Explotación de CVE-2021-4034").	**SÍ (Aplicado en Práctica 1 y Auditado/Explotado en Práctica 4):** • **En Práctica 1 (Ex3):** Se aplicó directamente el principio de mínimo privilegio en Debian 13 configurando el archivo /etc/sudoers (usermod -aG sudo) para que el usuario opere con permisos estándar y sólo eleve privilegios de forma controlada. • **En Práctica 4:** Se auditó el control de privilegios en webserver con LinPEAS, identificando permisos excesivos (666/777 en sockets de root) y binarios con bit **SUID** de root (/usr/bin/pkexec), compilando y ejecutando el exploit CVE-2021-4034 (*PwnKit*) para demostrar la escalación a uid=0(root).
PR.AT-01 PR.AT-02	**Concientización y capacitación en ciberseguridad para el personal general (PR.AT-01) y para individuos en roles especializados (PR.AT-02).** • Ex1--Ex4: Capacitar al personal para reconocer ingeniería social, cumplir políticas de uso aceptable, elegir contraseñas robustas y proteger datos críticos según su rol.	**Actividad 1, Actividad 6 y Actividad 7** (Actividad 1/main.tex; Actividad4/320206968_Actividad6 (1).pdf RSK-10; Actividad7/main.tex Sec. IV Acción 5).	**SÍ (Aplicado Metodológicamente en Actividades 6 y 7):** En las Actividades 6 y 7 se diseñaron los planes de concientización y evaluación anual para mitigar errores humanos, ingeniería social y fuga involuntaria de código fuente o datos sensibles en herramientas externas.
PR.DS-01	**Se protege la confidencialidad, integridad y disponibilidad de los datos en reposo (*data-at-rest*).** • Ex1: **Usar cifrado, firmas digitales y hashes criptográficos para proteger la confidencialidad e integridad de los datos almacenados en archivos, bases de datos e imágenes**. • Ex3: Confirmar la integridad del software validando firmas o hashes.	**Prácticas 5, 6 y 7, y Actividades 1, 3, 4 y 6** (Practica5/main.tex cálculo de sha256sum y análisis de SHA512-crypt; Practica6/main.tex auditoría de passwords.txt; Practica7/main.tex cálculo de hash con certutil -hashfile ... SHA256).	**SÍ (Aplicación Práctica Directa en Prácticas 5, 6 y 7):** • **En Práctica 5 (Ex1):** Se utilizó la herramienta sha256sum para generar resúmenes criptográficos SHA-256 de los archivos almacenados (passwd y shadow) y se analizó la protección de credenciales en reposo mediante hashes salados SHA512-crypt (6). • **En Práctica 6 (Ex1):** Se demostró el riesgo de almacenar datos sensibles en reposo sin cifrar al hallar credenciales en texto claro dentro de ProjectX_CodeBackup/config/passwords.txt. • **En Práctica 7 (Ex1, Ex3):** En Windows Server 2012 R2 se verificó la integridad criptográfica del archivo de código fuente bot.py ejecutando certutil -hashfile bot.py SHA256.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
PR.DS-02	**Se protege la confidencialidad, integridad y disponibilidad de los datos en tránsito (*data-in-transit*).** • Ex1: **Usar cifrado, firmas digitales y hashes criptográficos para proteger la confidencialidad e integridad de las comunicaciones de red**. • Ex2: Cifrar o bloquear automáticamente comunicaciones salientes que contengan datos sensibles (DLP). • Ex3: Bloquear acceso a servicios web externos no autorizados desde las redes de la organización.	**Prácticas 2, 4, 5 y 7, y Actividades 3, 4, 6 y 7** (Practica2/main.tex Sec. 5 auditoría TLS con nuclei; Practica5/main.tex transferencia cifrada scp + validación sha256sum; Practica7/main.tex túnel cifrado SSH ssh -L; Actividad7/main.tex Sec. IV DLP/CASB).	**SÍ (Aplicación Práctica en Prácticas 2, 5 y 7, y Metodológica en Clase):** • **En Práctica 2 (Ex1):** Se auditó la seguridad de datos en tránsito del servidor ssa.ingenieria.unam.mx con nuclei, detectando versiones obsoletas TLS 1.0/1.1 y suites CBC débiles, y documentando su remediación con TLS 1.2/1.3. • **En Práctica 5 (Ex1):** Se transfirieron archivos por red mediante el protocolo cifrado scp (sobre SSH en puerto 13337) y se compararon los hashes sha256sum en origen y destino para comprobar que no hubo alteración en tránsito. • **En Práctica 7 (Ex1):** Se encapsuló el tráfico RDP dentro de un túnel cifrado SSH (ssh -p 13337 -L 3389:10.0.0.201:3389). • **En Actividad 7 (Ex2, Ex3):** Se diseñaron reglas de inspección SSL/TLS, CASB y Endpoint DLP para bloquear la exfiltración de datos en tránsito hacia servicios externos no autorizados.
PR.DS-10	**Se protege la confidencialidad, integridad y disponibilidad de los datos en uso (*data-in-use*).** • Ex1--Ex2: Eliminar datos confidenciales de memoria cuando no se necesiten y proteger datos en uso contra acceso por otros procesos de la misma plataforma.	**Tarea 4 y Actividades 4 y 7** (Tarea4/main.tex Conf. 5 inyección de procesos en memoria T1055; Actividad7/main.tex Sec. IV aislamiento de datos en inferencia de IA).	**Analizado en Tarea 4 y Aplicado Metodológicamente en Actividad 7:** En la **Tarea 4** se estudió cómo el malware compromete datos y código en memoria mediante técnicas de *Process Injection* (T1055), y en la **Actividad 7** se especificó el uso de entornos aislados con política de *Zero-Data Retention* durante el procesamiento de prompts.
PR.DS-11	**Se crean, protegen, mantienen y prueban copias de seguridad (respaldos) de los datos.** • Ex1--Ex3: Crear respaldos periódicos, probar su restauración y **almacenarlos de forma segura (cifrados e inmutables/offline) para que un incidente o atacante no los comprometa**.	**Práctica 6, Tarea 4 y Actividades 3 y 6** (Practica6/main.tex Sec. "Búsqueda y análisis de respaldos"; Tarea4/main.tex Conf. 6 "Breaking the Defenders"; Actividad3/main.tex; Actividad4/320206968_Actividad6 (1).pdf RSK-01).	**SÍ (Auditado Prácticamente en Práctica 6, Visto en Tarea 4 y en Clase):** • **En Práctica 6:** Se localizaron y auditaron los archivos de respaldo /root/respaldo.tar.gz y /var/backups/Project.old.tar.gz mediante tar -ztvf, comprobando que almacenaban código y credenciales sin cifrar dentro del mismo servidor comprometido. • **En Tarea 4 (Conf. 6):** Se analizó cómo los operadores de ransomware buscan destruir o cifrar los respaldos locales antes de desplegar el ataque. • **En Actividades 3 y 6:** Se contempló el uso de respaldos inmutables y aislados para mitigar ataques de ransomware.
PR.PS-01	**Se establecen y aplican prácticas de gestión de configuración.** • Ex1: Establecer líneas base endurecidas (*hardened baselines*) bajo el principio de mínima funcionalidad. • Ex2: **Revisar todas las configuraciones que puedan impactar la ciberseguridad al instalar o administrar software**.	**Prácticas 1, 2, 3 y 4, y Actividades 4 y 7** (Practica1/main.tex; Practica2/main.tex; Practica3/main.tex; Practica4/main.tex auditoría de configuración con LinPEAS; Actividad7/main.tex Sec. IV GPOs).	**SÍ (Aplicado en Práctica 1 y Auditado en Prácticas 2, 3 y 4):** En la **Práctica 1** se realizó la configuración base del sistema Debian 13, y en las **Prácticas 2, 3 y 4** se auditaron configuraciones inseguras en servidores web y Linux (como mover SSH al puerto 13337 como "seguridad por oscuridad" sin deshabilitar autenticación por contraseña débil, o dejar permisos 666 en sockets del sistema).

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
PR.PS-02	**El software se mantiene, reemplaza y elimina de forma acorde con el riesgo.** • Ex1: **Realizar parches y actualizaciones de rutina y de emergencia**. • Ex3: **Reemplazar versiones de software y servicios al final de su vida útil (EOL) por versiones soportadas y mantenidas**.	**Prácticas 1, 2 y 4, y Actividad 4** (Practica1/main.tex Sec. "Mantenimiento y Actualización del Sistema"; Practica2/main.tex Sec. 4 detección de PHP/Apache EOL; Practica4/main.tex Debian 8.11 EOL y pkexec; Actividad3/main.tex Sec. 8).	**SÍ (Ejecutado en Práctica 1 y Auditado en Prácticas 2 y 4):** • **En Práctica 1 (Ex1):** Se ejecutó de forma práctica la actualización de listas de paquetes y parches del sistema operativo Debian 13 mediante `sudo apt update && sudo apt upgrade`. • **En Prácticas 2 y 4 (Ex3):** Se demostró el impacto directo de mantener software EOL sin soporte ni parches (explotando CVE-2021-4034 en Debian 8.11 para obtener acceso root).
PR.PS-04	**Los registros de auditoría (logs) se generan y ponen a disposición para el monitoreo continuo.** • Ex1--Ex2: Configurar sistemas operativos, aplicaciones y servicios para generar registros de log y enviarlos de forma segura a la infraestructura central de logging (SIEM).	**Tarea 4, Tarea 1 y Actividades 3 y 7** (Tarea4/main.tex Conf. 1 "Obfuscated Tale: PowerShell 4103/4104 y Sysmon 1, 7, 17"; Tarea1/main.tex syslog; Actividad3/main.tex; Actividad7/main.tex).	**Estudiado a Fondo en Tarea 4 y Tarea 1, y Aplicado en Clase:** En la **Tarea 4 (Conferencia 1)** se estudió específicamente qué fuentes de logs deben habilitarse en los sistemas operativos para detectar ataques modernos: **PowerShell Event IDs 4103 y 4104** (*Module & Script Block Logging*) y **Sysmon Event IDs 1, 7 y 17**, así como su envío hacia el SIEM.
PR.PS-05	**Se previene la instalación y ejecución de software no autorizado.** • Ex1--Ex4: Restringir la instalación y ejecución de software sólo a repositorios y productos aprobados, verificando su fuente.	**Práctica 1 y Actividad 7** (Practica1/main.tex configuración de /etc/apt/sources.list; Actividad7/main.tex Sec. IV bloqueo de extensiones/software no autorizado).	**SÍ (Aplicado en Práctica 1 y Planificado en Actividad 7):** En la **Práctica 1** se configuraron y verificaron los repositorios oficiales firmados de Debian en /etc/apt/sources.list antes de instalar paquetes. En la **Actividad 7** se diseñó el bloqueo de extensiones y navegadores no autorizados mediante políticas de grupo (GPO).
PR.PS-06	**Las prácticas de desarrollo seguro de software se integran y monitorean a lo largo del ciclo de vida de desarrollo (SDLC).** • Ex1--Ex2: Proteger los componentes del software desarrollado contra manipulación y asegurar que no contenga vulnerabilidades ni credenciales expuestas.	**Prácticas 2, 6 y 7, y Actividades 4 y 7** (Practica2/main.tex Sec. 5 auditoría de SRI en scripts web; Practica6/main.tex hallazgo de credenciales en ProjectX_CodeBackup; Practica7/main.tex verificación SHA-256 de bot.py; Actividad7/main.tex Sec. IV escaneo pre-commit).	**SÍ (Auditado Prácticamente en Prácticas 2, 6 y 7, y Aplicado en Clase):** • **En Práctica 2:** Se detectó la falta del atributo *Subresource Integrity* (SRI) al cargar librerías externas en páginas web. • **En Práctica 6:** Se identificó la mala práctica de almacenar contraseñas en texto plano dentro del árbol de código (config/passwords.txt). • **En Práctica 7:** Se validó la integridad del código fuente de bot.py mediante su hash SHA256.
PR.IR-01	**Las redes y los entornos están protegidos contra el acceso y uso lógico no autorizado.** • Ex1--Ex2: **Segmentar lógicamente las redes de la organización según límites de confianza, permitiendo sólo las comunicaciones requeridas entre segmentos**.	**Prácticas 6 y 7, y Actividades 3, 6 y 7** (Practica6/main.tex descubrimiento de red interna 10.0.0.0/24; Practica7/main.tex prueba de aislamiento y pivoteo SSH; Actividad3/main.tex Sec. 7 diagrama de 4 zonas).	**SÍ (Comprobado Prácticamente en Prácticas 6 y 7, y Diseñado en Clase):** En la **Práctica 7** se comprobó en laboratorio la segmentación lógica entre la red 192.168.177.0/24 y la red interna 10.0.0.0/24 (verificando que un ping directo desde EvilBox a 10.0.0.201 falla con 100 % de pérdida), y se demostró cómo un servidor puente (webserver) con dos tarjetas de red permite saltar dicha segmentación mediante un túnel SSH (ssh -L 3389:10.0.0.201:3389) si no se restringe el reenvío de puertos.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
PR.IR-03 PR.IR-04	**Mecanismos de resiliencia (PR.IR-03: alta disponibilidad, balanceo de carga) y capacidad adecuada de recursos (PR.IR-04: mitigación DDoS).**	**Práctica 2 y Actividades 3, 5 y 6** (Practica2/main.tex Sec. 5 detección de Cloudflare WAF/CDN con nuclei; Actividad3/main.tex Sec. 4 y 10.2; Actividad4/ 320206968_Actividad6 (1).pdf RSK-03).	**SÍ (Verificado en Práctica 2 y Diseñado en Actividades 3 y 6):** En la **Práctica 2** se identificó mediante nuclei la protección de alta disponibilidad y mitigación DDoS brindada por **Cloudflare** frente al portal ssa.ingenieria.unam.mx, y en las **Actividades 3 y 6** se diseñaron esquemas de alta disponibilidad (HA) y mitigación de ataques DDoS.

Subcategorías de PROTECT (PR) no vistas en el curso (3 de 22): PR.AA-06 (control de acceso físico con guardias, cerraduras y cámaras), PR.PS-03 (mantenimiento y destrucción física de hardware obsoleto) y PR.IR-02 (protección contra amenazas ambientales como incendios o inundaciones).

4.4. Función 4: DETECT (DE) — Monitoreo Continuo y Análisis de Eventos Adversos

La función **DETECT (DE)** alcanzó un **90.9 % de cobertura** en el curso, destacando de manera especial la **Tarea 1** (dedicada por completo a **Estrategias de Deception y Honeypots**, lo cual corresponde literalmente a DE.CM-03 Ex3), la **Tarea 4** (dedicada a ingeniería de detección, telemetría PowerShell/Sysmon y correlación en el SIEM en **MITRE ATT&CKcon 7.0**), la **Práctica 6** (inspección de procesos y conexiones activas) y la **Actividad 7** (monitoreo mediante KRIs).

Tabla 6: Subcategorías y actividades de la función **DETECT (DE)** vistas y aplicadas en el curso.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
DE.CM-01	**Las redes y los servicios de red se monitorean para encontrar eventos potencialmente adversos.** • Ex1: Monitorear DNS, BGP y otros servicios de red. • Ex2: Monitorear las redes en busca de conexiones no autorizadas. • Ex4: Comparar flujos de red reales contra líneas base.	**Prácticas 2, 3, 6 y 7, y Actividades 3, 6 y 7** (Practica2/main.tex DNS; Practica6/main.tex; Practica7/main.tex validación de puertos con nc -zv; Actividad3/main.tex; Actividad7/main.tex Sec. V KRI 1).	**SÍ (Aplicado en Prácticas 2, 6 y 7, y en Actividades 3 y 7):** En las Prácticas 2, 6 y 7 se inspeccionaron registros DNS, interfaces y conexiones de red (dig, ifconfig -a, nc -zv), y en la Actividad 7 (KRI 1) se definió el monitoreo continuo de tráfico DNS/HTTPS saliente para detectar conexiones hacia servicios no autorizados.
DE.CM-03	**La actividad del personal y el uso de la tecnología se monitorean para encontrar eventos potencialmente adversos.** • Ex1: Usar análisis de comportamiento para detectar actividad anómala de usuarios y mitigar amenazas internas. • Ex2: Monitorear logs de control de acceso lógico. • Ex3: **Monitorear continuamente la tecnología de ciberengaño (*deception technology*), incluyendo cuentas de usuario señuelo, ante cualquier uso**.	**Tarea 1 y Actividades 6 y 7** (Tarea1/main.tex "Estrategias de Deception y Honeypots en la Ciberseguridad Defensiva"; Actividad7/main.tex Sec. IV–V).	**SÍ (Visto a Profundidad en Tarea 1 y Aplicado Metodológicamente en Act. 7):** • **En Tarea 1 (Ex3):** El ejemplo Ex3 de DE.CM-03 en csf2.xlsx corresponde de manera exacta al tema completo de la **Tarea 1**: desplegar y monitorear continuamente **Honeypots**, **Honey files** (passwords.docx), **Honey tokens** (llaves API en repositorios, credenciales VPN) y **cuentas de usuario señuelo en Active Directory** (para detectar *Kerberoasting*), donde cualquier intento de uso genera una alerta inmediata de alta fidelidad. • **En Actividad 7 (Ex1, Ex2):** Se diseñó el monitoreo de actividad de usuarios mediante DLP y CASB para detectar uso de herramientas no autorizadas (*ShadowAI*).

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
DE.CM-06	**Las actividades y servicios de proveedores externos se monitorean para encontrar eventos potencialmente adversos.** • Ex1--Ex2: Monitorear actividades de administración remota de proveedores y **monitorear la actividad de servicios basados en la nube e integraciones de terceros para detectar desviaciones**.	**Tarea 4 y Actividades 6 y 7** (Tarea4/main.tex Conf. 2 "Multi-Tenant Kill Chain Correlation en entornos SaaS" y Conf. 6 MSPs; Actividad4/320206968_Actividad6 (1).pdf RSK-09; Actividad7/main.tex).	**SÍ (Analizado en Tarea 4 y Aplicado en Actividades 6 y 7):** En la **Tarea 4 (Conferencias 2 y 6)** se estudió cómo monitorear integraciones OAuth/SaaS de terceros y herramientas de proveedores de servicios administrados (MSP) que suelen ser abusadas para propagar ataques entre clientes.
DE.CM-09	**El hardware y software de cómputo, los entornos de ejecución (*runtime*) y sus datos se monitorean para encontrar eventos potencialmente adversos.** • Ex1: **Monitorear correo, web, servicios de colaboración y otros vectores para detectar malware, phishing y exfiltración de datos**. • Ex2--Ex5: Monitorear intentos de autenticación, desviaciones de configuración y salud de endpoints (EDR).	**Práctica 6, Tarea 4 y Actividades 3, 6 y 7** (Practica6/main.tex inspección de procesos en ejecución ps aux awf; Tarea4/main.tex Conf. 1, 5 y 6 monitoreo con EDR/Sysmon; Actividad7/main.tex Sec. IV–V Endpoint DLP).	**SÍ (Aplicado en Práctica 6, Analizado en Tarea 4 y Diseñado en Clase):** • **En Práctica 6:** Se auditó el árbol de procesos en ejecución (ps aux awf) en el servidor Linux para identificar servicios activos. • **En Tarea 4 (Conf. 1, 5 y 6):** Se estudió el monitoreo del entorno de ejecución (*runtime*) mediante sensores EDR y Sysmon para detectar inyección de procesos (T1055), ejecución de scripts ofuscados en PowerShell y desactivación de defensas (*AMSI/ETW/BYOVD*). • **En Actividad 7 (Ex1):** Se definió el monitoreo de exfiltración de datos en navegadores web mediante agentes Endpoint DLP (KRI 2).
DE.AE-02 DE.AE-03	**Análisis de eventos potencialmente adversos con herramientas SIEM (DE.AE-02) y correlación de información de múltiples fuentes (DE.AE-03).** • DE.AE-02 Ex1: Usar herramientas SIEM para monitorear continuamente eventos de log en busca de actividad maliciosa. • DE.AE-03 Ex2: **Usar tecnología de correlación de eventos (SIEM) para recolectar y cruzar información capturada por múltiples fuentes**.	**Tarea 4, Tarea 1 y Actividades 3 y 7** (Tarea4/main.tex Conf. 1 "Obfuscated Tale" y Conf. 2 "Multi-Tenant Kill Chain Correlation"; Tarea1/main.tex; Actividad3/main.tex; Actividad7/main.tex Sec. V).	**SÍ (Analizado a Profundidad en Tarea 4 y Aplicado en Actividad 7):** • **En Tarea 4:** En la Conferencia 1 se estudió cómo transformar registros crudos de PowerShell y Sysmon en reglas de detección dentro del **SIEM**, y en la Conferencia 2 se estudió la **correlación de múltiples fuentes** (identidad, red e integraciones SaaS) para reconstruir la cadena de ataque (*Kill Chain*). • **En Actividad 7 (Sec. V):** Se diseñó la correlación de 3 fuentes en el SIEM (logs de firewall/CASB, alertas de Endpoint DLP y escaneos de repositorios Git/Vault).
DE.AE-04	**Se comprende el impacto y alcance estimados de los eventos adversos.** • Ex1--Ex2: Estimar el impacto y alcance de un evento adverso mediante herramientas o análisis experto.	**Actividad 5, Actividad 6, Actividad 7 y Tarea 2** (Actividad3/main.tex Sec. 9.2; Actividad7/main.tex Sec. III; Tarea2/main.tex).	**SÍ (Aplicado Metodológicamente en Actividades 5, 6 y 7, y en Tarea 2):** Se analizó y cuantificó el alcance e impacto de eventos adversos tanto en casos reales (Actividad 5 y Tarea 2) como en la matriz cuantitativa de impacto de la Actividad 7.
DE.AE-06	**La información sobre eventos adversos se proporciona al personal y herramientas autorizados.** • Ex1: **Usar software de ciberseguridad para generar alertas y proporcionarlas al SOC y a los respondedores de incidentes**.	**Tarea 1, Tarea 4 y Actividades 3 y 7** (Tarea1/main.tex Sec. "Alertamiento vía syslog y webhooks hacia el SOC"; Tarea4/main.tex; Actividad7/main.tex).	**SÍ (Visto en Tarea 1 y Tarea 4, y Diseñado en Actividad 7):** En la **Tarea 1** se estudió la arquitectura de alertamiento desde los sensores y señuelos (*Honeypots*) mediante **syslog** y *webhooks* hacia los analistas del SOC.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
DE.AE-07	**La inteligencia de amenazas cibernéticas (CTI) y otra información contextual se integran en el análisis.** • Ex1--Ex3: Integrar feeds de CTI, inventarios de activos y divulgaciones de vulnerabilidades en el análisis de detección.	**Tarea 4, Tarea 2 y Actividades 3, 4, 5, 6 y 7** (Tarea4/main.tex integración de MITRE ATT&CK v21 y ATLAS en detección; Actividad3/main.tex Sec. 4–10; Actividad7/main.tex).	**SÍ (Analizado en Tarea 4 y Aplicado en Actividades 3 a 7):** En la **Tarea 4** se analizó el uso del marco **MITRE ATT&CK** y **ATLAS** para contextualizar detecciones, y en las **Actividades 3 a 7** se integraron el inventario de activos, los CVEs y la taxonomía de actores de amenaza para analizar los escenarios de riesgo.
DE.AE-08	**Se declaran incidentes cuando los eventos adversos cumplen los criterios de incidente definidos.** • Ex1: Aplicar criterios definidos para determinar si debe declararse un incidente. • Ex2: **Tomar en cuenta los falsos positivos conocidos al aplicar los criterios de incidente**.	**Tarea 1, Tarea 4 y Actividad 7** (Tarea1/main.tex Sec. "Reducción de ruido y falsos positivos en el SOC"; Tarea4/main.tex Conf. 2 "Anomalía vs. Evidencia de Compromiso" y Conf. 6; Actividad7/main.tex Sec. V KRI 3).	**SÍ (Estudiado a Fondo en Tareas 1 y 4, y Aplicado en Actividad 7):** • **En Tarea 1 (Ex2):** Se abordó como problema central el exceso de **falsos positivos** en el SOC y cómo las alertas provenientes de señuelos (*Deception*) permiten declarar un incidente con certeza casi absoluta. • **En Tarea 4 (Conf. 2):** Se estudió el criterio para diferenciar una anomalía aislada de una verdadera evidencia de compromiso antes de declarar un incidente. • **En Actividad 7 (KRI 3):** Se definió el umbral de disparo de incidente (≥ 1 llave o secreto expuesto).

Subcategorías de DETECT (DE) no vistas en el curso (1 de 11): DE.CM-02 (monitoreo del entorno físico mediante lectores de gafetes, bitácoras físicas de visitantes y cámaras de vigilancia).

4.5. Función 5: RESPOND (RS) — Respuesta y Mitigación de Incidentes

La función **RESPOND (RS)** se trabajó en la **Práctica 4, Práctica 5, Práctica 6 y Práctica 7** (preservación de integridad criptográfica de evidencias recolectadas, dimensionamiento del alcance de un compromiso en red interna y limpieza de artefactos), en las **Tareas 1, 2 y 4** (estrategias de respuesta con Honeypots, análisis de causa raíz de incidentes históricos como *Operation Triangulation*, *MOVEit* y *WannaCry*, y respuesta ante evasión de defensas) y en las **Actividades 5, 6 y 7**.

Tabla 7: Subcategorías y actividades de la función **RESPOND (RS)** vistas y aplicadas en el curso.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
RS.MA-01 RS.MA-02	**Ejecución del plan de respuesta a incidentes en coordinación con terceros (RS.MA-01) y triaje/validación de reportes de incidentes (RS.MA-02).** • RS.MA-01 Ex1--Ex2: Reporte de incidentes confirmados y apoyo de servicios externos de respuesta. • RS.MA-02 Ex1--Ex2: Triaje preliminar de alertas y estimación de severidad.	**Tarea 1, Tarea 4 y Actividad 7** (Tarea1/main.tex; Tarea4/main.tex Conf. 1, 2 y 6; Actividad7/main.tex Sec. III "Costo de Respuesta" y Sec. V).	**SÍ (Visto en Tareas 1 y 4, y Modelado en Actividad 7):** En las Tareas 1 y 4 se analizó el proceso de triaje de alertas en el SOC, y en la Actividad 7 (Sección III) se modelaron y costearon las actividades de respuesta a incidentes (triaje del SOC, auditoría forense de sesiones y remediación).

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
RS.MA-03	**Los incidentes se categorizan y priorizan.** • Ex1: **Categorizar incidentes según su tipo (fuga de datos / *data breach*, ransomware, DDoS, compromiso de cuenta)**. • Ex2: Priorizar incidentes según su alcance e impacto. • Ex3: **Seleccionar estrategias de respuesta para incidentes activos balanceando la necesidad de recuperarse rápidamente con la necesidad de observar al atacante o realizar una investigación más profunda**.	**Tarea 1, Tarea 2 y Actividades 5 y 6** (Tarea1/main.tex Sec. "Honeypots e interacción controlada con el atacante"; Tarea2/main.tex; Actividad3/main.tex Sec. 9.2 y 10.2; Actividad4/320206968_Actividad6(1).pdf).	**SÍ (Estudiado en Tarea 1 y Aplicado en Actividades 5 y 6):** • **En Tarea 1 (Ex3):** El ejemplo Ex3 de RS.MA-03 describe con exactitud el enfoque estudiado en la Tarea 1: utilizar entornos de **Deception / Honeypots** interactivos para observar las acciones y herramientas del intruso en un entorno aislado antes de proceder al bloqueo total. • **En Actividades 5 y 6 (Ex1, Ex2):** Se categorizaron y priorizaron los incidentes por tipo (ransomware, DDoS, exfiltración de datos, compromiso de credenciales y cadena de suministro).
RS.AN-03	**Se realiza un análisis para establecer qué ocurrió durante un incidente y la causa raíz del mismo.** • Ex1--Ex3: Determinar la secuencia de eventos, activos involucrados, vulnerabilidades, actores de amenaza y causas raíz subyacentes. • Ex4: **Revisar cualquier tecnología de ciberengaño (*cyber deception technology*) para obtener información adicional sobre el comportamiento del atacante**.	**Tarea 1, Tarea 2, Tarea 4 y Actividad 5** (Tarea1/main.tex *Deception*; Tarea2/main.tex casos *Operation Triangulation*, *MOVEit* y *WannaCry*; Actividad3/main.tex Sec. 9.2 análisis de 5 ciberataques reales).	**SÍ (Aplicado Analíticamente en Tarea 1, Tarea 2 y Actividad 5):** • **En Tarea 2 y Actividad 5 (Ex1--Ex3):** Se realizó el análisis de secuencia de eventos, vulnerabilidad explotada, actor de amenaza y causa raíz de 8 incidentes reales (*Operation Triangulation* CVE-2023-41990, *MOVEit Transfer*, *EternalBlue*/*WannaCry*, Continental, Yanfeng, Toyota S3, Hyundai y VW Cariad). • **En Tarea 1 (Ex4):** Se estudió el análisis del comportamiento del atacante a partir de los registros generados por señuelos y *Honeypots*.
RS.AN-07	**Se recolectan los datos y metadatos del incidente y se preserva su integridad y procedencia.** • Ex1: **Recolectar, preservar y salvaguardar la integridad de todos los datos pertinentes mediante procedimientos de preservación de evidencia**.	**Práctica 5 y Práctica 7** (Practica5/main.tex Sec. "Extracción de archivos y verificación con sha256sum"; Practica7/main.tex Sec. "Verificación con certutil SHA256").	**SÍ (Aplicación Práctica en Laboratorio en Prácticas 5 y 7):** • **En Práctica 5:** Al recolectar los archivos de evidencia (/etc/passwd y /etc/shadow) del servidor auditado, se calculó su hash criptográfico **SHA-256** (sha256sum) antes y después de su extracción por red (scp), garantizando formalmente que los archivos recolectados conservaron su integridad bit a bit. • **En Práctica 7:** Se recolectó y verificó la huella criptográfica SHA256 del archivo bot.py en el servidor Windows mediante certutil -hashfile.
RS.AN-08	**Se estima y valida la magnitud de un incidente.** • Ex1--Ex2: Revisar otros objetivos potenciales del incidente y ejecutar herramientas automatizadas en los objetivos para buscar indicadores y alcance del compromiso.	**Práctica 4, Práctica 6 y Actividad 7** (Practica4/main.tex linpeas.sh; Practica6/main.tex auditoría interna y script escaner.sh; Actividad7/main.tex).	**SÍ (Aplicado Prácticamente en Prácticas 4 y 6):** En las Prácticas 4 y 6 se ejecutaron herramientas de enumeración automatizada (linpeas.sh y escaner.sh) para evaluar el alcance de la exposición dentro del servidor comprometido y descubrir qué otros hosts internos (10.0.0.201) eran alcanzables desde él.
RS.CO-02 RS.CO-03	**Notificación de incidentes a partes interesadas internas y externas según leyes o contratos (RS.CO-02) e intercambio de información (RS.CO-03).** • RS.CO-02 Ex1--Ex3: Seguir procedimientos de notificación de brechas de datos (*breach notification*) a clientes, socios y reguladores.	**Actividad 5, Actividad 6 y Actividad 7** (Actividad3/main.tex Sec. 9.2; Actividad7/main.tex Sec. III y V).	**SÍ (Analizado en Actividad 5 y Aplicado en Actividad 7):** En la Actividad 5 se revisaron los casos de notificación de brechas de datos (como la exposición de datos de 2.15 millones de clientes en Toyota y 800,000 en VW Cariad), y en la Actividad 7 se contemplaron las notificaciones legales y contractuales ante fuga de información.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
RS.MI-01 RS.MI-02	**Los incidentes son contenidos (RS.MI-01) y erradicados (RS.MI-02).** • RS.MI-01 Ex1--Ex2: Ejecutar acciones de contención automáticas o manuales (bloqueo de red/sesiones). • RS.MI-02 Ex1--Ex2: Ejecutar acciones de erradicación (eliminación de artefactos maliciosos y revocación/rotación de credenciales comprometidas).	**Práctica 4 y Actividades 3, 6 y 7** (Practica4/main.tex limpieza de artefactos con make clean; Actividad7/main.tex Sec. IV–V bloqueo en firewall y rotación de llaves en < 4 horas).	**SÍ (Ejercitado en Práctica 4 y Diseñado en Actividad 7):** • **En Práctica 4:** Al finalizar la prueba de escalación de privilegios con CVE-2021-4034, se ejecutó make clean y eliminación de los archivos compilados para erradicar los artefactos de prueba del servidor. • **En Actividad 7:** Se definió el procedimiento de contención (bloqueo de sesiones en firewall/proxy) y erradicación mediante revocación y rotación inmediata (< 4 horas) de llaves y tokens comprometidos.

Subcategorías de RESPOND (RS) no vistas en el curso (3 de 13): RS.MA-04 (protocolos formales de escalamiento jerárquico de crisis), RS.MA-05 (criterios formales de activación de recuperación) y RS.AN-06 (bitácoras inmutables de las acciones de cada respondedor forense).

4.6. Función 6: RECOVER (RC) — Recuperación y Restauración

La función **RECOVER (RC)** se abordó de manera práctica en las **Prácticas 5, 6 y 7** mediante la inspección de respaldos comprimidos y la verificación criptográfica de integridad de archivos (RC.RP-03), así como de manera analítica y metodológica en las **Actividades 3, 5, 6 y 7** y en la **Tarea 4**.

Tabla 8: Subcategorías y actividades de la función **RECOVER (RC)** vistas y aplicadas en el curso.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
RC.RP-01 RC.RP-02	**Ejecución de la parte de recuperación del plan de respuesta a incidentes (RC.RP-01) y selección/priorización de acciones de recuperación (RC.RP-02).**	**Actividad 3, Actividad 5, Actividad 6 y Tarea 2** (Actividad3/main.tex Sec. 5 y Sec. 9.2; Actividad4/320206968_Actividad6 (1).pdf RSK-01; Tarea2/main.tex caso *WannaCry*).	**Visto en Clase (Actividades 5 y 6) y en Tarea 2:** Se analizaron los procesos de recuperación ante ataques de ransomware (*WannaCry* en Tarea 2; ataques de *Black Basta* y *LockBit* en Actividad 5) y se planificó el uso de respaldos para restaurar operaciones en la Actividad 6.
RC.RP-03	**La integridad de las copias de seguridad (respaldos) y otros activos de restauración se verifica antes de usarlos para la restauración.** • Ex1: **Revisar los activos de restauración en busca de indicadores de compromiso, corrupción de archivos y otros problemas de integridad antes de su uso**.	**Práctica 5, Práctica 6, Práctica 7 y Tarea 4** (Practica5/main.tex sha256sum; Practica6/main.tex inspección de /root/respaldo.tar.gz y Project.old.tar.gz con tar -ztvf; Practica7/main.tex certutil -hashfile ... SHA256; Tarea4/main.tex Conf. 6).	**SÍ (Aplicación Práctica en Laboratorio en Prácticas 5, 6 y 7):** En la **Práctica 6** se inspeccionó el contenido e integridad de los archivos de respaldo comprimidos (tar -ztvf) y en las **Prácticas 5 y 7** se verificó criptográficamente la integridad de los archivos mediante hashes **SHA-256** (sha256sum en Linux y certutil -hashfile ... SHA256 en Windows) para comprobar que no existiera corrupción o alteración.
RC.RP-04 RC.RP-05	**Consideración de funciones críticas de misión post-incidente (RC.RP-04) y verificación de integridad de activos restaurados (RC.RP-05).** • RC.RP-04 Ex1: Validar que los servicios esenciales se restauren en el orden apropiado según su criticidad.	**Actividad 3 y Actividad 6** (Actividad3/main.tex Sec. 3–4; Actividad4/320206968_Actividad6 (1).pdf).	**Aplicado Metodológicamente en Actividades 3 y 6:** Se establecieron las prioridades de continuidad y restauración operativa a partir de la criticidad de cada activo tecnológico identificado en clase.

Subcat. CSF 2.0	Descripción y Actividad / Ejemplo de Implementación (csf2.xlsx)	¿Dónde apareció en el curso? (Prácticas, Clases/Actividades, Tareas)	¿Se aplicó en algún momento? (Estado y Evidencia en el Curso)
RC.CO-03	**Las actividades de recuperación y el progreso en la restauración de capacidades operativas se comunican a las partes interesadas internas y externas.**	**Actividad 5 y Actividad 7** (Actividad3/main.tex Sec. 9.2; Actividad7/main.tex Sec. III).	**Analizado en Actividades 5 y 7:** Se revisó la comunicación de restauración operativa hacia clientes, socios y dirección tras incidentes de seguridad.

Subcategorías de RECOVER (RC) no vistas en el curso (2 de 8): RC.RP-06 (declaración formal de fin de recuperación y redacción del reporte *After-Action Report*) y RC.CO-04 (procedimientos operativos de relaciones públicas durante la recuperación).

5. Matriz Completa de las 106 Subcategorías de csf2.xlsx en el Curso

Para ofrecer una referencia completa del archivo csf2.xlsx, la Tabla 9 muestra las **106 subcategorías activas** del framework indicando si se vieron en el curso (**SÍ / NO**), en qué entregables aparecieron (Prácticas, Actividades, Presentación o Tareas) y bajo qué modalidad se aplicaron.

Tabla 9: Matriz general de las 106 subcategorías de csf2.xlsx frente a todo el historial del curso.

Código	Subcategoría NIST CSF 2.0 (csf2.xlsx)	¿Visto?	¿Dónde apareció en el curso?	¿Se aplicó? (Modalidad)
FUNCIÓN 1: GOVERN (GV) — 31 Subcategorías				
GV.OC-01	Misión organizacional comprendida e informa riesgos	**SÍ**	Actividad 2, Actividad 3 (Sec. 3)	SÍ (Aplicado en Actividades)
GV.OC-02	Stakeholders internos y externos comprendidos	**SÍ**	Actividad 2, 3, 6 y 7; Tarea 2	SÍ (Actividades y Tarea 2)
GV.OC-03	Requisitos legales, regulatorios y contractuales	**SÍ**	Actividad 1, Actividad 6 y 7 (Sec. III–IV)	SÍ (Aplicado en Actividades)
GV.OC-04	Objetivos y servicios críticos para stakeholders externos	**SÍ**	Actividad 2, Actividad 3 (Sec. 3–4), Act. 6	SÍ (Aplicado en Actividades)
GV.OC-05	Dependencias externas comprendidas e inventariadas	**SÍ**	**Práctica 2 (dig/whois AWS)**; Act. 2, 3 y 6	SÍ (Práctica 2 y Actividades)
GV.RM-01	Objetivos de gestión de riesgos establecidos y acordados	**SÍ**	Actividad 6, Actividad 7 (Sec. IV)	SÍ (Aplicado en Actividades)
GV.RM-02	Declaraciones de apetito y tolerancia al riesgo (riesgo residual)	**SÍ**	**Tarea 4 (Conf. 3)**; Actividad 7 (Sec. V KRIs)	SÍ (Tarea 4 y Actividad 7)
GV.RM-03	Riesgos cibernéticos incluidos en ERM empresarial	**SÍ**	Actividad 6, Actividad 7 (Sec. II–III)	SÍ (Aplicado en Actividad 7)
GV.RM-04	Dirección estratégica de opciones de respuesta (Mitigar/Transferir/Evitar/Aceptar)	**SÍ**	Actividad 6 (Sec. 2), Actividad 7 (Sec. IV)	SÍ (Aplicado en Act. 6 y 7)
GV.RM-05	Líneas de comunicación de riesgos en la organización	**SÍ**	Actividad 6, Actividad 7 (Sec. I, IV, V)	SÍ (Aplicado en Act. 6 y 7)
GV.RM-06	Método estandarizado para calcular, documentar y priorizar riesgos	**SÍ**	**Act. 4 (CVSS), Act. 6 (Registro), Act. 7 ($R = F \times I$)**	SÍ (Aplicado en Act. 4, 6 y 7)
GV.RM-07	Oportunidades estratégicas (riesgos positivos / SWOT)	NO	No visto en el curso	No cubierto
GV.RR-01	Liderazgo responsable y cultura ética consciente del riesgo	**SÍ**	**Tarea 2 (Ética profesional)**; Actividad 6 y 7	Visto en Tarea 2 y Actividades
GV.RR-02	Roles, responsabilidades y propietarios de riesgo establecidos	**SÍ**	Actividad 6 (Propietarios), Actividad 7 (POA&M)	SÍ (Aplicado en Act. 6 y 7)
GV.RR-03	Recursos adecuados asignados según estrategia de riesgo	**SÍ**	**Tarea 4 (Conf. 3)**; Actividad 7 (Sec. III–IV)	SÍ (Tarea 4 y Actividad 7)

Código	Subcategoría NIST CSF 2.0 (csf2.xlsx)	¿Visto?	¿Dónde apareció en el curso?	¿Se aplicó? (Modalidad)
GV.RR-04	Ciberseguridad incluida en prácticas de Recursos Humanos	**SÍ**	Actividad 5, Actividad 7 (Acción 5)	Visto / Planificado en Act. 7
GV.PO-01	Política de gestión de riesgos establecida y comunicada	**SÍ**	Actividad 1, Actividad 7 (Acción 5)	SÍ (Actividad 1 y Actividad 7)
GV.PO-02	Política actualizada ante cambios tecnológicos (**adopción de IA**)	**SÍ**	**Actividad 6 y Actividad 7 (ShadowAI)**	SÍ (Aplicado en Act. 6 y 7)
GV.OV-01	Resultados de la estrategia revisados para ajustar dirección	**SÍ**	Actividad 6, Actividad 7	SÍ (Aplicado en Act. 6 y 7)
GV.OV-02	Estrategia revisada y ajustada a la luz de incidentes	**SÍ**	Actividad 5 (Sec. 9.2), Actividad 6	SÍ (Aplicado en Act. 5 y 6)
GV.OV-03	Evaluación del desempeño mediante KPIs y **KRIs**	**SÍ**	**Actividad 7 (Sec. V: 3 KRIs cuantitativos)**	SÍ (Aplicado en Actividad 7)
GV.SC-01	Programa y estrategia de cadena de suministro (C-SCRM)	**SÍ**	Actividad 2, 3 y 6	Visto en Clase (Act. 2 y 6)
GV.SC-02	Roles de ciberseguridad para proveedores y socios	**SÍ**	Actividad 2, 6 y 7	Visto en Clase (Act. 2, 6 y 7)
GV.SC-03	C-SCRM integrado en la gestión de riesgos empresarial	**SÍ**	Actividad 5 y Actividad 6 (RSK-09)	SÍ (Aplicado en Act. 5 y 6)
GV.SC-04	Proveedores conocidos y priorizados por criticidad	**SÍ**	**Práctica 2**; Actividad 2 y Actividad 3	SÍ (Práctica 2 y Actividades)
GV.SC-05	Requisitos de seguridad en contratos con proveedores	**SÍ**	Actividad 6 (RSK-09), Actividad 7 (Sec. III–IV)	SÍ (Aplicado en Act. 6 y 7)
GV.SC-06	Debida diligencia previa a relaciones formales con proveedores	NO	No visto en el curso	No cubierto
GV.SC-07	Riesgos de proveedores evaluados y monitoreados	**SÍ**	Actividad 5 (Sec. 9.2), Actividad 6, Tarea 4	SÍ (Act. 5, 6 y Tarea 4)
GV.SC-08	Proveedores relevantes incluidos en ejercicios de incidentes	NO	No visto en el curso	No cubierto
GV.SC-09	Prácticas de procedencia (*provenance*) en ciclo de vida	NO	No visto en el curso	No cubierto
GV.SC-10	Planes para conclusión o terminación de contratos con proveedores	NO	No visto en el curso	No cubierto
FUNCIÓN 2: IDENTIFY (ID) — 21 Subcategorías				
ID.AM-01	Inventarios de hardware mantenidos y descubrimiento en red	**SÍ**	**Prácticas 3, 6 y 7 (nmap/escaner.sh)**; Act. 3	SÍ (Aplicado en Lab y Clase)
ID.AM-02	Inventarios de software, servicios y sistemas mantenidos	**SÍ**	**Prácticas 2 (subfinder/httpx), 3, 6, 7**; Act. 3	SÍ (Aplicado en Lab y Clase)
ID.AM-03	Representaciones de comunicación de red y flujos de datos	**SÍ**	**Prácticas 6 y 7 (route -n)**; Act. 3 (Diagrama TikZ)	SÍ (Aplicado en Lab y Clase)
ID.AM-04	Inventarios de servicios provistos por proveedores externos	**SÍ**	**Práctica 2 (AWS/Cloudflare)**; Act. 3 y Act. 7	SÍ (Aplicado en Lab y Clase)
ID.AM-05	Activos priorizados por clasificación, criticidad e impacto	**SÍ**	Actividad 3 (Sec. 4: 12 activos), Actividad 6	SÍ (Aplicado en Act. 3 y 6)
ID.AM-07	Inventarios y descubrimiento de datos sensibles y metadatos	**SÍ**	**Práctica 6 (find/grep), Prác. 7**; Act. 3 y 7	SÍ (Aplicado en Lab y Clase)
ID.AM-08	Ciclo de vida, sistemas EOL e identificación de **Shadow IT / AI**	**SÍ**	**Prácticas 1, 2 y 4 (EOL)**; Act. 6 y 7 (ShadowAI)	SÍ (Aplicado en Lab y Clase)
ID.RA-01	Vulnerabilidades en activos identificadas, validadas y registradas	**SÍ**	**Práctica 2 (nuclei), Práctica 4 (LinPEAS)**; Act. 4	SÍ (Aplicado en Lab y Clase)
ID.RA-02	Ciberinteligencia (CTI) recibida de fuentes y foros	**SÍ**	**Práctica 2 (VirusTotal API)**; Act. 5; **Tarea 4 (ATT&CK)**	SÍ (Práctica 2, Act. 5, Tarea 4)
ID.RA-03	Amenazas internas y externas identificadas y registradas	**SÍ**	**Act. 5 y Presentación HTML**; Act. 6 y 7; Tarea 4	SÍ (Act. 5, HTML, Act. 6 y 7)
ID.RA-04	Impactos potenciales y probabilidades identificados y registrados	**SÍ**	Actividad 6 (10 escenarios), Actividad 7 (Sec. III)	SÍ (Aplicado en Act. 6 y 7)

Código	Subcategoría NIST CSF 2.0 (csf2.xlsx)	¿Visto?	¿Dónde apareció en el curso?	¿Se aplicó? (Modalidad)
ID.RA-05	Amenazas, vulnerabilidades, probabilidades e impactos informan priorización	**SÍ**	Actividad 4, 5, 6 y 7	SÍ (Aplicado en Act. 4 a 7)
ID.RA-06	Respuestas al riesgo elegidas, planificadas y rastreadas (**POA&M / Registro**)	**SÍ**	**Actividad 6 (Registro), Actividad 7 (POA&M)**	SÍ (Aplicado en Act. 6 y 7)
ID.RA-07	Cambios y excepciones gestionados y evaluados por riesgo	**SÍ**	**Tarea 4 (Conf. 3)**; Actividad 7 (Sec. IV)	Visto en Tarea 4 y Act. 7
ID.RA-08	Procesos para recibir y analizar divulgaciones de vulnerabilidades	**SÍ**	**Tarea 2 (Zero-Days / Bug Bounty)**; Actividad 4	Estudiado en Tarea 2 y Act. 4
ID.RA-09	Autenticidad e integridad de hardware/software evaluada antes de adquirir	NO	No visto en el curso	No cubierto
ID.RA-10	Proveedores críticos evaluados antes de la adquisición	NO	No visto en el curso	No cubierto
ID.IM-01	Mejoras identificadas a partir de evaluaciones	**SÍ**	**Prácticas 2–7**; Actividad 7 y 8; **Tarea 4 (Conf. 5)**	SÍ (Aplicado en Lab y Clase)
ID.IM-02	Mejoras identificadas a partir de pruebas y **Penetration Testing**	**SÍ**	**Prácticas 2 a 7 (Pentesting completo)**; Tarea 4	SÍ (Aplicado en Prácticas 2–7)
ID.IM-03	Mejoras identificadas de la ejecución de procesos operativos	**SÍ**	Actividad 5, 6 y 7; Tarea 4	Visto en Clase y Tarea 4
ID.IM-04	Planes de respuesta a incidentes y gestión de vulnerabilidades	**SÍ**	Actividad 4 (Plan de mitigación CVE), Act. 6 y 7	SÍ (Aplicado en Act. 4, 6 y 7)
FUNCIÓN 3: PROTECT (PR) — 22 Subcategorías				
PR.AA-01	Identidades y credenciales gestionadas para usuarios y servicios	**SÍ**	**Práctica 1, 2 (API keys), 5 y 6**; Act. 3 y 7	SÍ (Aplicado en Lab y Clase)
PR.AA-02	Identidades verificadas y vinculadas a credenciales individuales	**SÍ**	**Práctica 1, 3 y 6**; Actividad 3 y 7	SÍ (Aplicado en Lab y Clase)
PR.AA-03	Usuarios y servicios autenticados (auditoría de fortaleza de contraseñas)	**SÍ**	**Práctica 3 (Hydra), Prác. 5 (John), Prác. 7**; Act. 3	SÍ (Auditado en Prácticas 3, 5, 7)
PR.AA-04	Aserciones de identidad protegidas y verificadas (SSO, OAuth 2.0)	**SÍ**	Actividad 3 y 7; **Tarea 4 (Conf. 2 SaaS)**	SÍ (Actividades 3, 7 y Tarea 4)
PR.AA-05	Permisos de acceso y principio de mínimo privilegio (sudoers, SUID)	**SÍ**	**Práctica 1 (/etc/sudoers), Prác. 4 (CVE-2021-4034)**	SÍ (Aplicado en Prác. 1 y 4)
PR.AA-06	Acceso físico a los activos gestionado y monitoreado	NO	No visto en el curso	No cubierto
PR.AT-01	Concientización y capacitación general al personal	**SÍ**	Actividad 6 (RSK-10), Actividad 7 (Acción 5)	SÍ (Planificado en Act. 6 y 7)
PR.AT-02	Capacitación a individuos en roles especializados	**SÍ**	Actividad 7 (Sec. IV Acción 5)	SÍ (Planificado en Actividad 7)
PR.DS-01	Protección e integridad de datos en reposo (**SHA-256**, cifrado)	**SÍ**	**Práctica 5 (sha256sum), Prác. 6, Prác. 7 (certutil)**	SÍ (Aplicado en Prácticas 5–7)
PR.DS-02	Protección de datos en tránsito (**TLS, SCP, Túnel SSH**, DLP)	**SÍ**	**Práctica 2 (nuclei TLS), Prác. 5 (scp), Prác. 7 (ssh -L)**	SÍ (Aplicado en Prác. 2, 5, 7 y Act. 7)
PR.DS-10	Protección de datos en uso (memoria y aislamiento de procesos)	**SÍ**	**Tarea 4 (Conf. 5 T1055)**; Actividad 7 (Acción 4)	Visto en Tarea 4 y Actividad 7
PR.DS-11	Copias de seguridad (respaldos) creadas y protegidas	**SÍ**	**Práctica 6 (respaldo.tar.gz)**; **Tarea 4 (Conf. 6)**; Act. 6	SÍ (Auditado en Prác. 6 y Tarea 4)
PR.PS-01	Prácticas de gestión de configuración y endurecimiento	**SÍ**	**Prácticas 1, 3 y 4 (LinPEAS)**; Actividad 7 (GPOs)	SÍ (Aplicado en Prác. 1, 3, 4 y Act. 7)
PR.PS-02	Software mantenido (apt upgrade) y reemplazo de versiones EOL	**SÍ**	**Práctica 1 (apt), Prác. 2 (PHP EOL), Prác. 4**; Act. 4	SÍ (Aplicado en Prácticas 1, 2 y 4)
PR.PS-03	Hardware mantenido, reemplazado y desechado de forma segura	NO	No visto en el curso	No cubierto
PR.PS-04	Registros de log generados y disponibles para monitoreo continuo	**SÍ**	**Tarea 4 (PowerShell 4103/4104, Sysmon 1,7,17)**; Tarea 1	Estudiado en Tarea 4 y Tarea 1
PR.PS-05	Prevención de instalación y ejecución de software no autorizado	**SÍ**	**Práctica 1 (sources.list)**; Actividad 7 (Acciones 1 y 3)	SÍ (Aplicado en Prác. 1 y Act. 7)

Código	Subcategoría NIST CSF 2.0 (csf2.xlsx)	¿Visto?	¿Dónde apareció en el curso?	¿Se aplicó? (Modalidad)
PR.PS-06	Prácticas de desarrollo seguro de software (SRI, código y secretos)	**SÍ**	**Práctica 2 (SRI), Prác. 6 (passwords.txt), Prác. 7 (bot.py)**	SÍ (Auditado en Prácticas 2, 6 y 7)
PR.IR-01	Redes protegidas y segmentadas lógicamente	**SÍ**	**Prácticas 6 y 7 (aislamiento 10.0.0.0/24 y pivoteo)**; Act. 3	SÍ (Comprobado en Prác. 6–7 y Act. 3)
PR.IR-02	Activos tecnológicos protegidos contra amenazas ambientales	NO	No visto en el curso	No cubierto
PR.IR-03	Mecanismos de resiliencia (Alta Disponibilidad, CDN/WAF)	**SÍ**	**Práctica 2 (Cloudflare WAF)**; Actividad 3	SÍ (Verificado en Prác. 2 y Act. 3)
PR.IR-04	Capacidad adecuada de recursos para asegurar disponibilidad (DDoS)	**SÍ**	**Práctica 2**; Actividad 3, 5 y 6 (RSK-03)	SÍ (Práctica 2 y Actividades)
FUNCIÓN 4: DETECT (DE) — 11 Subcategorías				
DE.CM-01	Redes y servicios de red monitoreados ante eventos adversos	**SÍ**	**Prácticas 2, 3, 6 y 7**; Actividad 3 y Act. 7 (KRI 1)	SÍ (Prácticas y Actividad 7)
DE.CM-02	Entorno físico monitoreado ante eventos adversos	NO	No visto en el curso	No cubierto
DE.CM-03	Monitoreo de actividad de usuarios y **tecnología de Deception / Honeypots**	**SÍ**	**Tarea 1 (Honeypots, Honey files y Honey tokens)**; Act. 7	SÍ (Tema central de Tarea 1 y Act. 7)
DE.CM-06	Actividades y servicios de proveedores externos monitoreados	**SÍ**	**Tarea 4 (Conf. 2 SaaS y Conf. 6 MSP)**; Act. 6 y 7	Estudiado en Tarea 4 y Act. 6–7
DE.CM-09	Hardware, software, runtime y datos monitoreados (procesos, EDR, DLP)	**SÍ**	**Práctica 6 (ps aux awf)**; **Tarea 4 (Sysmon/EDR)**; Act. 7	SÍ (Práctica 6, Tarea 4 y Act. 7)
DE.AE-02	Eventos potencialmente adversos analizados con herramientas SIEM	**SÍ**	**Tarea 4 (Conf. 1 SIEM)**; Tarea 1; Actividad 3 y 7	Estudiado en Tarea 4 y Act. 7
DE.AE-03	Información correlacionada de múltiples fuentes	**SÍ**	**Tarea 4 (Conf. 2 Kill Chain Correlation)**; Act. 7 (Sec. V)	Estudiado en Tarea 4 y Act. 7
DE.AE-04	Impacto y alcance estimados de eventos adversos comprendidos	**SÍ**	Actividad 5, 6 y 7 (Sec. III); Tarea 2	SÍ (Aplicado en Act. 5, 6 y 7)
DE.AE-06	Información de eventos adversos provista al SOC (syslog/webhooks)	**SÍ**	**Tarea 1 (Alertas syslog/webhooks al SOC)**; Act. 7	Estudiado en Tarea 1 y Act. 7
DE.AE-07	Inteligencia de amenazas (CTI) y contexto integrados en el análisis	**SÍ**	**Tarea 4 (MITRE ATT&CK / ATLAS)**; Act. 3 a 7	SÍ (Tarea 4 y Actividades 3–7)
DE.AE-08	Incidentes declarados según criterios y reducción de falsos positivos	**SÍ**	**Tarea 1 (Falsos positivos)**, **Tarea 4 (Conf. 2)**, Act. 7	Estudiado en Tareas 1, 4 y Act. 7
FUNCIÓN 5: RESPOND (RS) — 13 Subcategorías				
RS.MA-01	Plan de respuesta a incidentes ejecutado con terceros relevantes	**SÍ**	Actividad 7 (Sec. III), Tarea 4 (Conf. 6)	Visto en Tarea 4 y Actividad 7
RS.MA-02	Reportes de incidentes clasificados (triaje) y validados	**SÍ**	**Tarea 1**, **Tarea 4 (Conf. 1 y 2)**, Actividad 7	Estudiado en Tareas 1, 4 y Act. 7
RS.MA-03	Categorización de incidentes y balance con observación en **Honeypot**	**SÍ**	**Tarea 1 (Honeypots)**; Tarea 2; Actividad 5 y 6	Estudiado en Tarea 1 y Act. 5–6
RS.MA-04	Incidentes escalados o elevados según sea necesario	NO	No visto en el curso	No cubierto
RS.MA-05	Aplicación de criterios para iniciar la recuperación de incidentes	NO	No visto en el curso	No cubierto
RS.AN-03	Análisis de causa raíz de incidentes y revisión de **Deception**	**SÍ**	**Tarea 1 (*Deception*)**, **Tarea 2 (3 casos)**, Act. 5 (5 casos)	SÍ (Tareas 1, 2 y Actividad 5)
RS.AN-06	Acciones realizadas durante la investigación registradas de forma inmutable	NO	No visto en el curso	No cubierto
RS.AN-07	Datos del incidente recolectados preservando su integridad (**SHA-256**)	**SÍ**	**Práctica 5 (sha256sum) y Práctica 7 (certutil)**	SÍ (Aplicado en Prácticas 5 y 7)
RS.AN-08	Magnitud del incidente estimada y validada en otros objetivos	**SÍ**	**Práctica 4 (LinPEAS) y Práctica 6 (escaner.sh)**	SÍ (Aplicado en Prácticas 4 y 6)
RS.CO-02	Stakeholders internos y externos notificados de brechas de datos	**SÍ**	Actividad 5 (Sec. 9.2), Actividad 7 (Sec. III)	SÍ (Actividad 5 y Actividad 7)

Código	Subcategoría NIST CSF 2.0 (csf2.xlsx)	¿Visto?	¿Dónde apareció en el curso?	¿Se aplicó? (Modalidad)
RS.CO-03	Información compartida con partes designadas	**SÍ**	Actividad 6 y Actividad 7 (Sec. III–V)	SÍ (Aplicado en Act. 6 y 7)
RS.MI-01	Incidentes contenidos (bloqueo de sesiones y red)	**SÍ**	Actividad 3, 6 y 7	Diseñado en Actividades 6 y 7
RS.MI-02	Incidentes erradicados (limpieza de artefactos y rotación de llaves)	**SÍ**	**Práctica 4 (`make clean`)**; Actividad 7 (rotación < 4h)	SÍ (Práctica 4 y Actividad 7)
FUNCIÓN 6: RECOVER (RC) — 8 Subcategorías				
RC.RP-01	Ejecución del plan de recuperación de incidentes	**SÍ**	Actividad 5 y 6; Tarea 2 (WannaCry)	Visto en Act. 5, 6 y Tarea 2
RC.RP-02	Acciones de recuperación seleccionadas y priorizadas	**SÍ**	Actividad 6 (RSK-01, RSK-04, RSK-09)	Planificado en Actividad 6
RC.RP-03	Integridad de respaldos y archivos verificada antes de usar (**SHA-256**)	**SÍ**	**Práctica 5 (sha256sum), Prác. 6 (tar), Prác. 7 (certutil)**	SÍ (Aplicado en Prácticas 5–7)
RC.RP-04	Funciones críticas de misión consideradas post-incidente	**SÍ**	Actividad 3 y Actividad 6	SÍ (Aplicado en Act. 3 y 6)
RC.RP-05	Integridad de activos restaurados verificada	**SÍ**	Práctica 7; Actividad 6 y 7	Visto en Práctica 7 y Act. 6–7
RC.RP-06	Fin de recuperación declarado y reporte *After-Action*	NO	No visto en el curso	No cubierto
RC.CO-03	Progreso de recuperación comunicado a stakeholders	**SÍ**	Actividad 5 (Sec. 9.2), Actividad 7 (Sec. III)	Visto en Actividades 5 y 7
RC.CO-04	Actualizaciones públicas sobre recuperación compartidas	NO	Sólo mencionado en casos históricos (Act. 5)	No cubierto

6. Conclusiones sobre la Aplicación del NIST CSF 2.0 en el Curso

Al revisar todas las carpetas del repositorio frente al archivo `csf2.xlsx` de **The NIST Cybersecurity Framework 2.0**, se concluye que el curso logró cubrir **89 de las 106 subcategorías activas (84.0 %)** mediante tres mecanismos complementarios:

1. **En las Prácticas de Laboratorio (Prácticas 1 a 7 — 30 subcategorías aplicadas técnicamente):** Se ejecutaron en tiempo real las actividades técnicas de **IDENTIFY**, **PROTECT**, **DETECT**, **RESPOND** y **RECOVER**:

   - **Identificación de activos, redes y dependencias (`GV.OC-05`, `ID.AM-01` a `ID.AM-04`, `ID.AM-07`, `ID.AM-08`):** Uso práctico de `subfinder`, `dig`, `whois`, `httpx`, `nmap`, `ps aux awf`, `route -n`, `ifconfig -a`, `find`, `grep -rnI`, `systeminfo` y el script propio `escaner.sh`.

   - **Escaneo de vulnerabilidades y Penetration Testing (`ID.RA-01`, `ID.RA-02`, `ID.IM-01`, `ID.IM-02`):** Uso de APIs de ciberinteligencia (VirusTotal/GitHub), escaneo con `nuclei` sobre `ssa.ingenieria.unam.mx`, enumeración local con `LinPEAS` y explotación real de `CVE-2021-4034` (*PwnKit*).

   - **Protección de privilegios, contraseñas, parches, criptografía y segmentación (`PR.AA-01` a `PR.AA-05`, `PR.DS-01`, `PR.DS-02`, `PR.DS-11`, `PR.PS-01`, `PR.PS-02`, `PR.IR-01`, `RS.AN-07`, `RC.RP-03`):** Configuración de `/etc/sudoers` y actualización con `apt update && apt upgrade` (Práctica 1), auditoría de contraseñas con `Hydra` (Práctica 3) y `John the Ripper` (Práctica 5), verificación de integridad con `sha256sum` y `certutil -hashfile ... SHA256` (Prácticas 5 y 7), auditoría de respaldos con `tar -ztvf` (Práctica 6) y pivoteo entre redes segmentadas mediante túneles cifrados SSH (`ssh -L`) y RDP (Práctica 7).

2. **En las Actividades de Clase y Presentación Interactiva (Actividades 1 a 7 y `Actividad3/html` — 59 subcategorías aplicadas metodológicamente):** Se aplicaron las metodologías de **GOVERN** e **IDENTIFY**: diferenciación entre políticas de Seguridad de la Información y controles de Ciberseguridad (Actividad 1), análisis de contexto organizacional y cadena de suministro (Actividad 2), levantamiento de inventarios de activos y diagramación de zonas de red (Actividad 3), evaluación de vulnerabilidades con **CVSS v3.1**, `CVE` y `CWE` (Actividad 4), inteligencia de amenazas y exposición de la taxonomía de adversarios en presentación web HTML (Actividad 5), construcción del **Registro de Riesgos** en Forma 1 y Forma 2 (Actividad 6), y cálculo cuantitativo de riesgos ($R = F \times I_{\text{prom}}$), Plan de Acción (**POA&M**) y diseño de **KRIs** (Actividad 7).

3. **En las Tareas y Conferencias (Tareas 1 a 4 — 37 subcategorías analizadas):** Se cubrieron a profundidad los temas de **DETECT** y **RESPOND**: despliegue y monitoreo de **Honeypots, Honey files y Honey tokens** para eliminar falsos positivos en el SOC (**Tarea 1** → `DE.CM-03 Ex3`, `DE.AE-08`, `RS.MA-03 Ex3`, `RS.AN-03 Ex4`), análisis de **Zero-Days, mercados de exploits y ética en la divulgación responsable** (**Tarea 2** → `GV.RR-01`, `ID.RA-08`, `RS.AN-03`), y telemetría avanzada de **PowerShell, Sysmon, correlación SaaS multi-tenant, riesgo residual (*The Defensible Minimum*) y MITRE ATT&CK v21 / ATLAS** (**Tarea 4** → `GV.RM-02`, `PR.PS-04`, `DE.CM-06`, `DE.CM-09`, `DE.AE-02`, `DE.AE-03`).

Referencias Bibliográficas

National Institute of Standards and Technology. (2024, febrero). *The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29)* (inf. téc.). U.S. Department of Commerce, National Institute of Standards y Technology. https://doi.org/10.6028/NIST.CSWP.29